

Issues_Summary

Open workable items (current_location = Issues), regenerated from the SQLite single-source-of-truth (§11.4.12).

Counts by Type × Status

Type	Status	Count
Bug	In progress	11
Bug	Operator-blocked	1
Bug	Queued	43
Bug	Ready for testing	4
Task	In progress	12
Task	Queued	30
Task	Ready for testing	2
TOTAL		103

Items

ATM ID	Type	Status	Severity	Description
BOB-008	Bug	Operator-blocked	—	OPERATOR DECISION (2026-08-26, interactive clarification): COMPLETE CAPTCHA FLOW ONCE Session established, path is DECIDED: the operator drives the interactive CAPTCHA flow at /api/v1/autotracker/captcha then /login once, and stores the resulting bb_session. The cool path and the cookies-file autoload path offered and NOT chosen. THE BLOCK M BUT DOES NOT LIFT: the operator must physically drive the flow — no agent can CAPTCHA (§11.4.52 honest operator_at boundary). AGENT PREP OWED BEFORE HAND-OFF, so the operator’s single attempt succeeds rather than discovering a broken endpoint mid-flow: verify both endpoints reachable and correctly wired end-to-end the session is actually PERSISTED after successful post (not merely accepted), a

ATM ID	Type	Status	Severity	Description
				a stored session is actually USED by a subsequent search. Honest limitation to front: a stored bb_session expires, so the requires repeating — that cost was accepted the decision. This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent in and supersedes any prior agent-chosen this question. Options not chosen are not above so a future reader does not re-litigate settled call (§11.4.112(5) bounded-verdict discipline applied to decisions). — prior follows — RuTracker automated login by CAPTCHA
BOB-065	Task	Queued	High	Lava P2: Egress diagnosis and VPN-host routing (containers pkg/egress)
BOB-066	Task	In progress	High	Lava P3: BOBA_UPSTREAM_PROXY in proxy + qBitTorrent-go + Jackett + com forward
BOB-068	Bug	In progress	High	RD2-00: unattributed, unreviewed Auto mechanism pushing to main
BOB-069	Task	In progress	High	RD2-40: §11.4.238 QA-discovery-channel — ongoing coverage-escape backfill
BOB-074	Task	In progress	Medium	RD2-07: DDoS-class testing fully absent mandated test-type matrix
				OPERATOR DECISION (2026-08-26, interactive clarification): UNKNOWN INSTRUMENT THE NEXT OCCURRENCE operator does not currently know which produces the +0500 Auto-commit fast-f so the three candidate answers (second session / intentional rsync job / stale job remain open. DECIDED ACTION: stop h host this session cannot reach (§11.4.6 state is not knowable without access) and INSTRUMENT the mechanism so the next occurrence identifies itself. Forensic capture: committer identity, hostname, time offset, push timing, and the git remote u recorded at Auto-commit time into a tra forensic log. ACCEPTANCE: the next Au commit event yields a captured record n origin host — at which point this item re one of the three original branches with rather than a guess. This is the §11.4.10 reversible-safe move: it costs little, bloc nothing, and converts a recurring myste self-identifying event. This answer is re
BOB-077	Task	Queued	High	

ATM ID	Type	Status	Severity	Description
				consumer DATA per §11.4.35 — it is the operator’s stated choice, not an agent in and supersedes any prior agent-chosen this question. Options not chosen are not above so a future reader does not re-litigate settled call (§11.4.112(5) bounded-verdict discipline applied to decisions). — prior follows — RD2-10: Identify second host the Auto-commit rsync/sync mechanism (OPERATOR-DECISION)
BOB-078	Task	Queued	High	RD2-11: Once identified, wire Auto-commit mechanism through §11.4.234 dedicated push script OR retire it
BOB-080	Task	Queued	High	RD2-13: Retroactive Fable-xhigh code re the substantive Auto-commit diffs
BOB-082	Task	Queued	High	RD2-15: Create BOB-064..067 workable the four Lava-porting findings (closes G
BOB-085	Task	Queued	Medium	RD2-18: Create top-level Boba proxy/me service v1.0.0 readiness ledger (closes C
BOB-088	Task	Queued	Medium	RD2-21: Complete/verify README Trac + Status Documents table row-completo (GA-07 remainder)
BOB-090	Task	In progress	Medium	RD2-25: HelixQA Challenge entry exerc three start.sh subcommands end-to-end real compose stack
BOB-093	Task	In progress	High	RD2-28: Live compose bring-up + verify ReDoS regex bounds deployed to contain (closes runtime half of GA-12)
BOB-094	Task	In progress	Medium	RD2-29: Author tests/stress/ test_tracker_fetch_stress_chaos.py with fault injection
BOB-095	Task	In progress	Medium	RD2-30: Author tests/stress/ test_scheduler_hooks_sse_stress_chaos. side triangle
BOB-097	Task	Queued	Low	RD2-32: Author DDoS-class coverage for download-proxy/merge endpoints (canonical of RD2-07)
BOB-100	Task	Queued	Low	RD2-39: Bump submodules/jackett one (canonical impl of RD2-09)
				OPERATOR DECISION (2026-08-26, interactive clarification): DEFER PA
BOB-101	Task	Queued	High	Go --profile go parity remains a goal but LONGER a v1.0.0 release blocker. RW-1 move to a post-1.0 milestone and stop g tag. Nothing advertised is removed, so stays clean and no §11.4.90 Obsolete cl

ATM ID	Type	Status	Severity	Description
BOB-102	Task	In progress	Medium	warranted. The BOB-141 measured fact unchanged: the Go container's Dockerfile ONE binary binding only :7187; nothing :7186 or :7188 despite compose setting PROXY_PORT/BRIDGE_PORT. CLAUDE map already describes what the container ACTUALLY does and needs no amendment to this decision. This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inference and supersedes any prior agent-chosen answer to this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions). — prior item text follows — GA-19/RW-09: Is -profile go p a release goal? (gates RW-10..13) — OPERATOR-DECISION OPERATOR DECISION (2026-08-26, interactive clarification): KEEP 0.0.0.0 MANDATORY AUTH GUARD The tunnel is LAN-reachable — no bind address change to 127.0.0.1. The operator explicitly chose to preserve access from other devices on the network. THE DECISION CARRIES A BOUNDARY OBLIGATION: a permanent §11.4.135 requirement that guard MUST land that FAILS THE BUILD if LAN-reachable route ever stops demanding authentication. The operator accepted (and THE CONDITION that guard exists — with this decision is unprotected and the item is closeable. Guard requirements: enumerated from the authoritative source (FastAPI and handlers, boba-jackett) never a hand-made list; resolve real auth coverage not a guess string 'auth' (§11.4.201 real-condition); deliberately-public routes exempt ONLY if checked-in list with per-entry justification enumerated as honest gaps never silent TRUE + golden-FALSE fixtures per §11.4.35. This answer is recorded as consumer DATA per §11.4.35 — it is the operator's stated choice, not an agent inference, and supersedes any prior agent-chosen default on this question. Options not chosen are named above so a future reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict discipline applied to decisions). — prior item text follows — RW-05: LAN threat model — bind tunnel 127.0.0.1 or 0.0.0.0? — OPERATOR-DECISION

ATM ID	Type	Status	Severity	Description
BOB-104	Task	In progress	Medium	§11.4.238 followup: CodeGraph 1.5.0 nested-.gitignore regression challenge
BOB-106	Task	Queued	Medium	§11.4.238 followup: §11.4.84 quiescence helper for the unattributed auto-commit
BOB-107	Task	Queued	Medium	§11.4.238 followup: pre-dispatch existence for subagent task-brief source inputs
BOB-109	Task	Ready for testing	Medium	BOB-074 followup: scaling-class test code absent from mandated test-type matrix
BOB-110	Task	Queued	Medium	BOB-074 followup: UX-class test coverage (accessibility/usability) absent
BOB-111	Task	In progress	High	BOB-074 followup: configure real rate limit boba's 3 public HTTP endpoints
BOB-114	Task	Queued	Medium	BOB-074 followup: self-validation golden fixture for the rate-limit detector
BOB-121	Task	Ready for testing	Important	External watchdog for the forced-logout architectural gap (task #85, incident #3)
BOB-135	Bug	Ready for testing	Low	Test isolation: test_list_hooks_after_creation bulk suite (Permission denied /config)
BOB-137	Bug	In progress	High	Merge service on 7187 wedges while the process still serves 7186 (GIL starvation spinning thread)
BOB-141	Task	Queued	Low	CLAUDE.md claims the Go profile server 7186/7187/7188 but its container binds 7187 — doc contradicts the Dockerfile
BOB-143	Bug	Queued	Medium	Orphaned .worktrees/ dirs (46M, unresolved gitdir) pollute gate scan scope and manifest false BOB-126-class findings
BOB-149	Bug	Queued	Low	Managed-plugin count diverges 43/42/41 constitution, CLAUDE.md and the REAL badge; the badge is hand-maintained and unguarded
BOB-150	Task	Queued	Low	pre_build_verification.sh invariant label 44 but only 35 invariants are labelled
BOB-151	Task	Queued	Medium	CM-SCRIPT-DOCS-SYNC is a named gate implementation, and 24 of 36 scripts have companion doc
BOB-152	Bug	Queued	Medium	Constitution sweep walks vendored third code: 82% of one gate's 38,291 findings from submodules/
BOB-154	Bug	Ready for testing	Medium	Host venv and production container run starlette versions (1.4.1 vs 1.6.0)
BOB-156	Bug	Queued	Medium	BOB-145 event-loop regression guard is sensitive and flaky: 8786ms under host 900-1500ms ceiling calibrated on a quiet

ATM ID	Type	Status	Severity	Description
BOB-159	Bug	Queued	Medium	OPERATOR DECISION (2026-08-26, §11.4.66): REPAIR, THEN RE-VERIFY STABLE The warm ./start.sh path keeps the ownership repair against a live stack walks, re-verifies, and repeats until a path nothing new. Options not chosen: refuse repair while the stack is up and direct the operator to -recreate; stop the stack on path too (correct but ends 'warm'); accept document the window. WHY THIS MATTERS MORE THAN A NORMAL ITEM: this is a defect the whole 002-user-owned-downloaded feature exists to end. The -recreate path already fixed to order precondition -> download repair -> up so the walk sees a tree no container can write. The warm path was not, so a container can create a new non-owned file AFTER repair has passed that directory — the problem leaking back in through the other REQUIRED BY THE CHOSEN OPTION, the hard part: the loop MUST be BOUNDED on giving up it MUST report honestly that ownership is UNPROVEN rather than simply exiting 0 (§11.4.201(6)) — a loop that stops new files because it ran out of iterations: the same quiet zero as a genuinely clean active download creating files faster than a walk completes is the realistic non-convex case and must be named in the give-up. Recorded as consumer DATA per §11.4. operator's stated choice, not an agent in Options not chosen are named so a future does not re-litigate a settled call. — prior text follows — Reported-Via: §11.4.202 directive bug on 2026-08-21T19:01:17Z Reported-By: T041 independent review (IMPORTANT-2), partially remediated Verbatim report, verbatim): The -recreate path this round: run_ownership_precondition stack_down -> run_ownership_repair -> up so the repair walks a tree no container can write to. That ordering is now asserted behavior by three new checks in tests/unit/test_start_reload_recreate.sh, each killed by paired 1.1 mutation (11/11 RED-OK). The warm path is NOT covered by that fix and this bug tracks the remainder. On a warm ./start.sh gate runs before THIS invocation brings the stack up, but if the stack is ALREADY running containers write while the repair walks.

ATM ID	Type	Status	Severity	Description
				container can then create a new non-op owned file BEHIND the walk, after which completion marker records complete ownership that is not, and those stragglers are never repaired without a manual -force. BOU dismissed: after any successful pass the valid for the scope fingerprint and the marker short-circuits without walking (marker_is_valid so the window requires a stale-or-absent AND a live stack together. Declaring a marker entry re-arms the marker, which is exact that combination arises in practice. NO THIS ROUND, with the reason stated rather hidden: the clean guard is a cheap marker probe mode on scripts/ownership_repair.sh answers has-this-scope-been-repaired while walking the tree. The existing -dry-run serve: it deliberately SKIPS the marker (FORCE=0 && DRY_RUN=0 guard) and walks, so using it as a warm-start probe walk the tree twice on every start. Adding mode requires editing ownership_repair.sh another stream was actively editing during round; duplicating marker_is_valid into instead would be a near-identical fork (Deferred to this item rather than done unilaterally or silently. The misleading call at the warm-start call site (which claimed gate runs before any container writes) has been corrected to state this boundary honestly. Affected scope / file-scope manifest: (warm-start dispatch, run_ownership_guard site); scripts/ownership_repair.sh (marker path) Reproduction / context: 1. Ensure stack is UP. 2. Change config/owned_path so the scope fingerprint changes (this re-makes marker by design, data-model E2). 3. Run warm ./start.sh (no -recreate). 4. The ownership repair walks and chowns the declared tree. Containers are still running and able to do it. Acceptance criteria: A warm ./start.sh complete an ownership repair while a container that writes to a declared location is running. Either the repair is deferred with an active refusal naming -recreate, or the stack is ready for the walk. Asserted behaviourally in test_start_reload_recreate.sh alongside existing PRECONDITION_BEFORE_DOWN REPAIR_AFTER_DOWN / REPAIR_BEFORE_DOWN

ATM ID	Type	Status	Severity	Description
				checks, each with a paired 1.1 mutation it. Reported-Via: §11.4.202 reporting dire on 2026-08-21T19:02:48Z Reported-By What (the report, verbatim): Indepen §11.4.209 review (IMPORTANT-3) found the feature’s strongest automated check never executed by any runner: (1) tests/ownership/test_container_writes_owned — the §11.4.115 RED-turned-regression FR-011/FR-007, proven via a docker-con revert mutation — was moved out of tes integration/ (commit 58d340a, to escap autouse fixture hang) but no runner (ci. test.sh, run-all-tests.sh) was ever exten cover tests/ownership/. (2) tests/pre_bu test_.sh, the §1.1 paired-mutation meta- the scripts/pre_build/check_cm_.sh gate was executed by NOTHING — self-repo honestly in commit 04742d7’s own mes (‘STILL OPEN (reported, not fixed): test pre_build/ is executed by NOTHING’) b tracked as a workable item (a §11.4.197 requirements gap) and never wired into pre_build_verification.sh invariant 30, w globbed only tests/unit/test_.sh. Affecte file-scope manifest: ci.sh; scripts/ pre_build_verification.sh invariant 30 (C UNIT-TESTS-EXECUTED) Reproductio context: grep -rn test_container_writes_owned_files ci.sh run-all-tests.sh scripts/ returned zero ru (only docs/specs mentioned the path); g scripts/pre_build_verification.sh showed 30’s for-loop globbing only tests/unit/te never tests/pre_build/test_.sh. Accepta criteria: ci.sh gains a runtime-gated py ownership/ stage (skips honestly, rc=0, podman/docker present); scripts/ pre_build_verification.sh invariant 30’s covers both tests/unit/test_.sh and tests pre_build/test_*.sh, verified by an extra standalone run of the invariant’s exact l reporting a non-zero RAN count that inc files from both directories. Reported-Via: §11.4.202 reporting dire on 2026-08-21T19:31:12Z Reported-By BOB-092 remediation, residual finding report, verbatim): §11.4.69 names CM
BOB-160	Task	Queued	Medium	
BOB-161	Task	Queued	High	

ATM ID	Type	Status	Severity	Description
				OPEN-SKIP as one of three mandatory gates: it audits sink-side probe helpers if any code path converts an empty or unreachable response into a PASS-count for a feature class with a sink-side probe project does not have it. Why this matter rather than in the abstract: the BOB-09 remediation just removed TWO fail-open exactly this class from tests/e2e/test_live_stack_evidence.py — the nnm on-404 (already removed at 7baef2b) and surviving sibling at test_iporrents_is_authenticated_in_search skipped on 'not authenticated and status success' while asserting 'treating as tra outage'. That assertion was false for rejected credentials (upstream_http_403) and for container (plugin_env_missing), both of definitive product failures the product a classifies via error_type. Two fail-opens class, found one at a time, is the §11.4.1 extend-to-all-cases signal and the §11.4 coverage-escape signal together: the re not surface either, an agent reading code remediation's own guards are AST-struct lethal under three discriminating mutations they LIVE IN THE FILE THEY GUARD, deleting that file evades them entirely. A gate is the durable home because it audits corpus rather than one file. Honest bou (§11.4.6): this item does NOT claim the remediated fail-opens are unguarded — guarded, with runtime evidence (13 pas 97.36s against the live stack). It claims CLASS has no corpus-wide detector, so instance in a different file is invisible again. Affected scope / file-scope manifest: pre_build/ (gate absent); tests/e2e/test_live_stack_evidence.py (guards current inside the file they guard) Reproduction context: grep -rl 'CM-NO-FAIL-OPEN-S scripts/ tests/ returns exactly ONE hit, at tests/e2e/test_live_stack_evidence.py — the guards live in, not a gate. Control no same query for CM-OWNERSHIP-INVALID gate that does exist) returns 3 files, so the instrument can see gate tokens and there is a real absence, not a blind zero (§11.4 (b)). Acceptance criteria: A scripts/pro gate named CM-NO-FAIL-OPEN-SKIP e

ATM ID	Type	Status	Severity	Description
				wired into scripts/pre_build_verification audits sink-side probe helpers for code converting an empty/unreachable/error into a PASS-counting SKIP for a feature HAS a sink-side probe. It ships a golden fixture (a real fail-open -> gate FIRES) golden-FALSE-with-carrier (an honest to geo skip, and a comment merely MENT the phrase -> gate MUST NOT fire), per §11.4.107(10)/§11.4.201(1). Paired §1.1 makes the gate FAIL before the gate is Reported-Via: §11.4.202 reporting dire on 2026-08-21T19:35:02Z Reported-By: BOB-106/BOB-107 remediation, residual (the report, verbatim): The TESTS for guards are now executed: pre-build inva glob was extended from tests/unit + tes pre_build to also cover tests/hooks. ME before/after: the glob expanded to 27 su 0 under tests/hooks while 3 existed ther expands to 30 with 3 under tests/hooks. pass. But the GUARDS themselves are s invoked by nothing. check-brief-inputs.s honestly conductor-run rather than auto brief's required-input list lives in free-fc that the Agent tool's structured input d expose, so an automatic prompt-scrapir would itself be an unproven pattern-ma seam is the dispatch procedure, and tha documentation + habit change, not a ho unattributed-commit-guard.sh is differer why this item exists. Run against real h names 14 violating commits since the la (and 21 bare Auto-commit subjects exist all refs). Wiring it into the pre-build or seam AS-IS would therefore refuse ever immediately, on pre-existing debt noboc in the moment. That is precisely the 11. brownfield-adoption shape, and 11.4.66 put the choice with the operator, not wi agent inventing a ratchet. The options, the decision is a decision and not a defa immediate hard floor – the seam refuses 14 are attributed; (b) one-time monoton decrease ratchet (the 11.4.135 pattern) snapshot 14 as the baseline, the count r and may never rise, so day one is green disease cannot spread; (c) changed-com – gate only commits created from now c scheduled deadline for the historical 14
BOB-162	Task	Queued	Medium	

ATM ID	Type	Status	Severity	Description
BOB-163	Bug	In progress	Medium	report-only for a stated period, then esc Recommendation, with the reasoning ra just the pick: (b). It is the pattern this c already uses for exactly this situation, i the debt visible and bounded immediate cannot be satisfied by deleting the guar (11.4.227 closes that gaming channel). the operator's call and this item is not c until that answer is recorded. Honest b (11.4.6): this item does NOT claim the 1 commits are harmful in themselves - it their ATTRIBUTION is absent and that n currently prevents the 15th. Affected s file-scope manifest: scripts/hooks/unat commit-guard.sh; scripts/hooks/check-b inputs.sh; scripts/pre_build_verification scripts/commit-push-all.sh Reproduction context: Both guards run correctly by l are covered by passing tests (9/9 and 13 proven non-bluff against a no-op stub). I invoked by scripts/pre_build_verification scripts/commit-push-all.sh, so neither e standing detection pressure (11.4.226: with no execution seam is not coverage registration is not coverage). Acceptan criteria: Each guard is invoked by a n seam, OR carries a registered deferral p this item. For unattributed-commit-guar specifically, the operator has answered adoption question below and the answe recorded as consumer DATA - never an ratchet. OPERATOR DECISION (2026-08-26, interactive clarification): YES — 429 RESPONSIVE IF Retry-After IS WELL FORMED A 429 carrying a VALID Retry header counts as the sibling endpoint b RESPONSIVE. Assertion (c) of the DDoS challenge accepts 2xx OR a well-formed (positive integer seconds or valid HTTP PARSED, not merely present/non-empty DEGRADED remains: connection failure any 5xx, and a 429 with absent or malfo Retry-After. RESIDUAL RISK, accepted and to be stated in the script source per a genuinely wedged endpoint that happ answer 429-with-Retry-After would pass Retry-After parse narrows that window, not close it. Options (b) limiter-aware d (c) exempt healthz probe were both offe

ATM ID	Type	Status	Severity	Description
				NOT chosen. STILL OPEN, not covered decision: the detector counts 429 only, not 503, though the script header says '429 (or equivalent)'; counting 503 would collide with the crash detector's 5xx tally. Decide when the limiter lands limiters on :7185 and :7189. This is recorded as consumer DATA per §11.4.3.3, not the operator's stated choice, not an age-based inference, and supersedes any prior age-based default on this question. Options not chosen named above so a future reader does not litigate a settled call (§11.4.112(5) bounding verdict discipline applied to decisions). Item text follows — Reported-Via: §11.4.112(5) reporting directive bug on 2026-08-21T11:00:00Z. Reported-By: BOB-114 remediation, problem defect surfaced by BOB-111 landing a real challenge. What (the report, verbatim): PRE-EXISTING NOT INTRODUCED - and proven so rather than asserted: git diff shows assertion (c) is IDENTICAL to HEAD, and the failure regression against the unmodified HEAD script. What changed is not the challenge but the SYNTAX. BOB-111 appears at least partially delivered because :7187 now returns real 429s where previously returned none. :7185 and :7189 produce zero 429s. This is a 11.4.248-class corrosion risk and that is why it is filed rather than left as a footnote: run_all_challenges now fail INTERMITTENTLY, and an intermediate red trains everyone to re-run until green, which point a real regression is dismissed 'probably the flaky rate-limit one'. THE DECISION, which is an operator call under 11.4.66 and which I deliberately did NOT. Does a 429 from a WORKING limiter constitute a sibling endpoint being RESPONSIVE? (a) YES - 429 proves the endpoint is alive and corner-protecting itself. Assertion (c) accepts 2xx/429, and only a connection failure / 5xx counts as degraded. Risk: a genuinely working endpoint that happens to answer 429 with (b) NO - keep requiring 2xx, but make the challenge limiter-aware: drain or wait out the window before the sibling probe (retry-served, so the budget is knowable rather than guessed). (c) Probe siblings on a path that exempts (a healthz-class route), so the inference question is asked without spending the budget. Recommendation with reasoning, not just

ATM ID	Type	Status	Severity	Description
BOB-164	Bug	In progress	Medium	(a) composed with a bounded liveness of 429 carrying a well-formed Retry-After header as evidence of a live, correctly-behaving server. (b) makes the challenge slower and could choose a window value that will drift. But the server is 'responsive' here are a product judgement. The answer is recorded, not assumed. RELAY is stated as fact rather than folded in: the counts 429 only, not 503, though the script header says '429 (or equivalent)'. Counting would collide with the crash detector's Worth deciding when BOB-111 lands line :7185 and :7189. Affected scope / file-manifest: challenges/scripts/ddos_resilience_challenge.sh assertion endpoint isolation; run_all_challenges.sh invokes it Reproduction / context: Assertion requires a sibling-endpoint probe to answer (2xx). :7187 now enforces a real limiter (live: x-ratelimit-limit: 120, x-ratelimit-retry-after: 86, retry-after: 45, server: uvicorn). A full challenge run sends roughly 250 requests to :7187, so sibling probes fired during the endpoints' tiers land on an exhausted backend and receive 429 - which assertion (c) scores 'endpoint degraded'. Timing-dependent test measured PASS=5 FAIL=2; the UNMOVED HEAD script against the same live stack later measured PASS=7 FAIL=0 SKIP=0. Acceptance criteria: The operator has the classification question below, the answer is recorded as consumer DATA, and assertion implements it. The challenge then produces the same verdict across 3 consecutive runs on a rate-limited stack (11.4.50 deterministic consistency), and the fix ships a paired mutation proving assertion (c) still catches a genuinely degraded sibling endpoint - not just it must not blind it (11.4.201(1)). Reported-Via: §11.4.202 reporting directly on 2026-08-21T19:56:53Z Reported-By: BOB-110 UX-class coverage, discovered a new axe-core suite on its first live run Verdict, report, verbatim): This is a REAL user defect, not a test-tuning artifact, and it is caught by the automated regime rather than by squinting at the page - which is exactly the 11.4.238 posture the project is aiming for. A static-grep oracle would NOT have found it. Measured: the served root ships an empty

ATM ID	Type	Status	Severity	Description
				hydration, so any check reading the raw audits a page nobody sees. The violation exists in the hydrated DOM, which is why 11.4.170 requires a rendered oracle and value-equality assertions as the proof a correct. Severity reasoning, stated rather assumed: this is user-visible and affects primary dashboard heading, but it degrades legibility rather than breaking function, surface is operator-facing rather than public. Medium, not High. The failing test was FAILING on purpose (11.4.238) instead silenced or marked xfail. tests/ux/ current reports 1 failed, 16 passed; that 1 is this. Anyone reading a red UX suite should read this item, not as flakiness - and when the suite goes fully green, which is the state it is closed. HONEST SCOPE LIMIT (11.4.238) the dashboard landing view was scanned by jackson/* sub-routes and the ng-serve-hot:4200 route set were NOT audited - the commands to close both are recorded in testing/ux_accessibility.md. So this item reports nodes are a floor, not a total. Affected scope file-scope manifest: the Angular dashboard served at http://localhost:7187/ (same code as SPA as frontend/); production component not test files Reproduction / context: ux/test_live_dashboard_accessibility.py and the running merge service. axe-core v4.0.0 scanning a real Playwright-rendered JS DOM, reports color-contrast violations on 2 nodes. Measured pairs: .brand / h1 text on background #3c3f41 = 1.43-1.62:1 (large-text floor is 3:1); tagline #808080 / #3c3f41 = 2.68:1 (body-text floor is 4.5:1). Acceptance criteria: axe-core reports color-contrast violations against the live dashboard, with the fix made in product component CSS rather than by relaxing the assertion or excluding the rule (11.4.122 reconcile to the correct mechanism, never weaken the check). The existing tests/ux/ux_guard the guard and already fails today, so the test is captured - closure requires it flipping G against the live surface, which is runtime evidence per 11.4.226. Reported-Via: §11.4.202 reporting direct on 2026-08-21T20:00:08Z Reported-By: surfaced while capturing closure evidence
BOB-165	Bug	Queued	High	

ATM ID	Type	Status	Severity	Description
				BOB-092; diagnosed rather than worked What (the report, verbatim): This is a ABI-AFTER-INTERPRETER-UPGRADE of a missing package. The package is installed, compiled half is built for the previous interpreter. That distinction matters because 'pip install -r requirements.txt' style advice can appear to succeed without leaving the 313 artefact in place. WHY NOT NOTICED EARLIER, stated as fact that paths that DO work all avoid system python. ci.sh selects an interpreter through <code>_select_python</code>; the long-running suites session ran <code>.venv/bin/python -m pytest</code> and passed. So the automated regime is greener than the DOCUMENTED operator command - an 11.4.238-shaped gap, since the escape found by an agent capturing evidence reported by the regime. WORKAROUND (measured and theorised): <code>PYTEST_DISABLE_PLUGIN_AUTOLOAD=1</code> the needed plugins passed explicitly (<code>-p pytest_timeout ...</code>) avoids the schemathesis autoload that drags in jsonschema -> re -> rpds. That is a workaround, NOT the silence the import path rather than re- install, and it will surprise the next person runs the documented command verbatim. RELATED, and worth deciding together more than twice: BOB-154 wants .venv rebuilt to match the container (which runs CPython 3.12.13 while both system and venv run Python 3.12.13). There are therefore THREE interpreters. Whoever rebuilds the venv should configure it to resolve for the TARGET interpreter afterwards or this same class reappears one directly. HONEST BOUNDARY (11.4.6): this item should NOT claim any test is wrong or any product is broken. The product and the venv-run are unaffected. What is broken is the documented entry point. Affected scope / file-scope manifest: host user site-packages (<code>~/.local/lib/python3/site-packages/rpds/</code>); every CLANG documented 'python3 -m pytest ...' invocation any tooling that uses system python3 rather than <code>.venv/bin/python</code> Reproduction / <code>python3 -m pytest tests/e2e/test_live_stack_evidence.py -q -importmode=importlib -> ModuleNotFoundError: module named 'rpds.rpds', raised during collection via the schemathesis plugin and</code>

ATM ID	Type	Status	Severity	Description
				-> jsonschema -> referencing._core -> 1 MEASURED root cause: system python3 but ~/.local/lib/python3/site-packages/rpds.cpython-313-x86_64-linux-gnu.so - extension built for 3.13. rpds/init.py do 'from .rpds import *', and a 313-tagged importable by 3.14, so the submodule g does not exist for this interpreter. The v CORRECT and unaffected: .venv/lib64/p site-packages/rpds/ ships rpds.cpython- x86_64-linux-gnu.so and '.venv/bin/pytho import rpds' succeeds. Acceptance cri python3 -m pytest tests/unit/ -v -import mode=importlib - the command CLAUD documents - reaches collection without ModuleNotFoundError, OR CLAUDE.mo corrected to document the supported ru explicitly. Either way the documented c and the working command agree (11.4. guide that misleads is the documentatio equivalent of a PASS-bluff). WORKAROU EFFECTS MEASURED 2026-08-21 — th is not free, and the item previously impl PYTEST_DISABLE_PLUGIN_AUTOLOAD disables ALL plugin autoloader, not just th one, so anything the suite silently relied be re-enabled by hand: - It BREAKS 5 p env-dependent tests in tests/unit/ test_plugin_rutracker.py — TestConfig::test_default_mirrors, test_env_mirrors_override, test_get_env_with_default, test_get_mirrors_from_env_empty, test_get_mirrors_from_env_whitespace need an autoloader env plugin. PROVE caused by any in-flight change: running OWN copy of that file under identical fl produces the same 5 failures. - It makes -timeout=60 (set in pyproject.toml) an UNKNOWN ARGUMENT unless -p pyte is passed explicitly, so pytest.mark.time silently inert under the naive recipe — a believed to be time-bounded is not. - Wi autoload ON and only schemathesis dis no:schemathesis), that same file is 96/9 CONSEQUENCE FOR ANYONE USING WORKAROUND: -p no:schemathesis alon strictly better than blanket autoloader-dis where it suffices, because it removes on broken plugin. Where the blanket form

ATM ID	Type	Status	Severity	Description
BOB-167	Bug	Queued	Medium	-p pytest timeout must be added or time inert, and the 5 env-dependent failures recognised as workaround artifacts rather than filed as defects. That last point is the real issue: the workaround manufactures failures that are exactly like product defects. This does not solve the root cause (the venv's rpds ships a cpython-313 ABI tag CPython 3.14 cannot use) or the fix (rebuild the venv — BOB-154). The docs documents that the interim recipe has a 10000 radius, so nobody reads a workaround as a regression. WHAT. download-proxy exposes two SSE Events routes. They are the same expensive — long-lived connections that hold a worker generator for their lifetime — but only one is rate limit classed: routes.py:801 @router.get('/search/stream/{search_id}') @_rl('sse_stream') is rate limit classed routes.py:150 @router.get('/theme/stream') async def stream_theme(...) <- rate limiter decorator @_rl(cls) resolves to limiter.limit(limit_for(cls)), so /search/stream is bound to the sse_stream class while /theme/stream falls through to the application class. Measured live on the running stack: /api/theme/stream reports x-ratelimit-limit 120. PROVENANCE + A CORRECTION WORKING. KEEPING (§11.4.6). This was surfaced by BOB-109 scaling agent, whose report fragment was: 'sse_stream_limit_decorator is defined but not imported/applied nowhere ... SSE falls through the 120/minute default: 24x less protection. Framing is WRONG and was NOT filed as a bug. The agent searched for one symbol NAME and found wiring uses a different mechanism (@_rl('sse_stream')), and it IS applied — search/stream. Verified by reading routes.py:795-806 and the _rl helper at routes.py:46-51, with a control needle comparing other *_limit_decorator symbols show rate limit in api/init.py so the zero-hit was not a bug but a search. The agent's MEASUREMENT (120/minute theme/stream) was correct and is what we need. This is a real finding; its MECHANISM was confirmed. Halves are recorded so the next reader can re-derive the same wrong cause. WHY IT MATTERS. An unclassed SSE endpoint is the cheapest way to pin server resources: each connection is held open, and the default rate permits 120/min of them. The declared

ATM ID	Type	Status	Severity	Description
BOB-168	Task	In progress	Low	sse_stream class exists precisely because route shape needs a tighter bound than GETs. ACCEPTANCE. (a) A decision, record whether /theme/stream belongs in the sse class or genuinely warrants the default policy question, not automatically a bug. (b) If it belongs in sse_stream, the decorator applied and a test drives BOTH SSE routes asserts each returns its INTENDED class from x-ratelimit-limit, so a future route without a class is caught. (c) A guard that enumerates SSE-shaped routes and fails that carries no explicit rate-limit class – in general form, so the third SSE route does repeat this. (d) Honest boundary: this default claim 120/min is exploitable in this deployment with network_mode host and no reverse proxy; every caller shares the 127.0.0.1 bucket. BOB-111 measured and recorded separately. CLAIMED. No change made. The limit values were read from headers, never driven to exhaustion — the limiter is per-IP and scales with concurrent agents on this host (§11.4.201). WHAT. scripts/run_all_challenges.sh:66 “scaling_horizontal_challenge.sh” in its set. challenges/scripts/scaling_horizontal_challenge.sh does not record -n ‘66p’ scripts/run_all_challenges.sh “scaling_horizontal_challenge.sh” \$ ls challenges/scripts/scaling_horizontal_challenge.sh access ...: No such file or directory VERIFIED independently, not taken on report — see the BOB-109 scaling agent and re-check by direct invocation. WHY IT MATTERS: this is cosmetic or a §11.4.201 gate-honour defect depends entirely on how the runner has a missing entry, and that is the first thing to determine: if it SKIPS silently, the challenge advertises coverage it does not have (a claim-vs-reality row with no passing challenge behind it); if it FAILS, the runner is permitted for a reason unrelated to the system test, which trains readers to ignore it. Neither outcome is acceptable; they need different ACCEPTANCE. (a) Determine and record runner’s actual behaviour on the missing invoking it, not by reading it. (b) EITHER the challenge, OR remove the entry — v §11.4.124 discipline: check git history for whether it once existed and was deleted.

ATM ID	Type	Status	Severity	Description
				silently-dropped challenge is the more i defect. (c) If the runner silently skips m entries, that is its own finding: a missin challenge must be loud (§11.4.3 SKIP-w at minimum), never absent-and-quiet. S Low as a defect, but it sits on the challe coverage seam, so (c) may deserve its o CORRECTION 2026-08-22 (§11.4.6) — T ITEM’S PREMISE WAS FALSE, and the mine. Recorded openly rather than quie scaling_horizontal_challenge.sh EXISTS submodules/challenges/challenges/scrip scaling_horizontal_challenge.sh, execut bytes, dated Aug 7. So do all 14 other e the meta-runner. It was never deleted: a the roster at 1c959ba, the challenge its in the submodule at 873c0b1, and a pic search across both repositories and all finds ZERO deletions. HOW I GOT IT W run_all_challenges.sh reads submodules challenges/challenges/scripts/. I checke challenges/scripts/ — a DIFFERENT dir belonging to a DIFFERENT, glob-based Two similarly-named directories; I meas wrong one. That is a §11.4.201(9) field-i error. Worse, I wrote that it was “verifie invocation”: I had listed a directory and the aggregator, so the claim overstated evidence class as well as getting the an wrong. THE LESSON, which generalise item. In the SAME commit I correctly ca sibling agent making this exact class of BOB-167 — a zero-hit produced by sear symbol name — and applied a control n there. Then I omitted the needle one pa later on my own measurement. The dist that would have caught it: A CONTROL PROVES THE INSTRUMENT CAN SEE, NOT PROVE IT IS POINTED AT THE TH UNDER TEST. §11.4.201(7)(b) as comm applied guards blindness; it does not gu aiming. The needle for THIS query wou been to resolve the path the runner itse not to confirm that some directory listin WHAT IS ACTUALLY WRONG, and it is than what I filed. The missing-entry pat challenges by definition, so it can be ex safely. Run against a checkout where th submodule is absent — the ordinary sta clone made without -recursive — the R

ATM ID	Type	Status	Severity	Description
				runner (byte-identity sha-asserted, not a reports: PASS: 0 FAIL: 0 SKIP: 16 TOTAL OBSERVED EXIT CODE: 0 An ENTIRELY RUN BANK REPORTS SUCCESS. Not a dangling entry tolerated — the whole suite silently passes without executing anything is §11.4.201(6) false-null verbatim, and observed-reachable rather than constructed (§11.4.115(G)). REVISED ACCEPTANCE ANSWERED, though not as filed: the runner reports a loud, counted SKIP and then runs blocks, because the exit expression reached FAIL count. (b) The dangling-entry half nothing is dangling. (c) The real work is contract: a roster entry the runner cannot execute must not be indistinguishable from a healthy run. See the decision recorded in BOB-168/decision_missing_vs_skip.md. REPORTED NOT FIXED: scripts/pre_build_verification.sh:1792 carries the SKIP/MISSING conflation one level up, other runner. Filed separately.
BOB-169	Bug	In progress	Medium	WHAT. The §11.4.65 markdown-export runner requires every in-scope doc to ship .html twins. 286 of the 326 .html files under docs (excluding dist/ and node_modules/) are FRAGMENTS — they begin at
BOB-170	Task	Queued	Medium	WHAT. The BOB-109 scaling suite gates timing tests on loadavg_1m/nproc <= 0 on this 8-cpu host, a 1-minute load average below 6.0 — and SKIPS loudly otherwise. The gate is correct and was adopted for a gate (§11.4.201(8)): the author validated a 2% growth-exponent threshold, then observed FALSE-FAIL correct code at load 11.06 (span 2.136), and at load 15-23 measured spans of 2.358 against injected-cubic mean 2.278-2.331 — the signal is smaller than and the two are not separable in either. Gating was the honest response. THE P The gate has consequently NEVER RUN on its own precondition. Every recorded run took measured load 9.15-23; the independent measured 9.66 during review; the condition measured 6.45 at its lowest. GREEN point observed — at loads 9.4-11.6 (span 1.88) three stability runs (1.759/1.832/1.848) never once beneath the shipped ceiling. The author states this honestly as an inference from data rather than a run they can paste, a

ATM ID	Type	Status	Severity	Description
				reviewer confirmed the inference is sound (quiescence is strictly more favourable) inference is still not an observed run. W MATTERS (§11.4.226). A registered, top present guard that never executes is indistinguishable from a guard that would did. Nothing currently ensures it ever refreshes freshness contract, no scheduled quiet invocation, no tracked item — which is the unexecuted-standing-guard class §11.4.226 names, where registration gets treated as coverage while execution is nobody's job forensic precedent in that anchor is two guards that, when finally executed, immediately emitted latent FAILs. ACCEPTANCE. (a) both quiescence-gated timing tests on a whose 1-minute loadavg is genuinely < 1 — no agent fleet, no concurrent build — capture the run as an artifact showing the resolved load reading alongside the measurement span exponent, so the precondition is proven from the artifact and not asserted. (b) For observed GREEN polarity in the item artifact test source, replacing the current honest inference note. (c) If the gate FAILS under genuine quiescence, that is the finding exists to surface, and it reopens the threshold calibration question rather than being worked around. (d) Establish a freshness contract §11.4.226: how stale a quiescent verdict before the gate counts as uncovered against this does not silently return to never-existence HONEST BOUNDARY. This item does not the gate is wrong. The evidence points the way — quiescence is strictly more favourable than the loads where GREEN was already observed. It claims only that the run has happened, and that an unexecuted guard can be cited as coverage. PROVENANCE. R IMPORTANT-2 by the independent Fable substrate reviewer of the BOB-109 world independently corroborated: the review the SKIP is loud and prints its resolved load and confirmed the shipped tests do SKIP today's load. WHAT. Both rate limiters key their per-bucket on the LEFTMOST element of X-Forwarded-For when TRUST_FORWARDER is enabled: download-proxy/src/api/rate_limit.py:117-123 (:7187) and the no
BOB-171	Bug	Queued	Low	

ATM ID	Type	Status	Severity	Description
				limiter in plugins/download_proxy.py (:7) which was deliberately built to exact po with it. That element is CLIENT-SUPPL honest reverse proxy APPENDS the pee to the RIGHT of whatever arrived, so th entry is whatever the client sent — atta controlled by construction, not by misconfiguration. Consequences with th (1) rotating a forged leftmost value min unlimited sequence of fresh buckets, wh total bypass of the limit the flag is supp make MORE accurate; (2) it also defeat idle-reap cap, since each forged identity distinct key — the bucket map is a mem growth surface bounded only by the cap cap’s eviction then discards the budgets clients to make room for forged ones. N EXPLOITABLE AS DEPLOYED TODAY, a why this is Low, not High. TRUST_FORWARDED_FOR defaults OF sites, and the deployed stack runs netw host with no reverse proxy in front (ver across all five compose services), so pee addresses are real client IPs and no NA occurs. The defect is latent: it arms the someone puts a proxy in front and turns on to recover real client IPs — which is the situation the flag exists for. The fail is therefore ‘correct-looking configurati silently disables the limiter’, not ‘curre broken’. PROVENANCE. Raised as MIN the independent reviewer of the BOB-1 limiter work and independently confirm implementing agent, which noted it at E source sites as a tracked follow-up rath fixing it in that change. Filed here beca neither agent has write access to the tr WHY IT COVERS BOTH PORTS. :7186’s was built to deliberate policy parity wit including this parsing. Fixing one and n other would leave the two surfaces disa on client identity — worse than the sha because it becomes surface-dependent untestable as a single invariant. ACCEP (a) Replace leftmost-element parsing wi aware resolution at BOTH sites: either minus-N-trusted-hops, or a trusted-prox allowlist where only a peer inside the al may assert XFF at all — the choice is a deployment-topology decision and shou

ATM ID	Type	Status	Severity	Description
BOB-172	Bug	Ready for testing	High	recorded, not assumed. (b) A test that frotating leftmost element and asserts the key does NOT rotate, per site. (c) Paired mutation: restore leftmost parsing and t must FAIL. (d) Negative control (§11.4.2 with TRUST_FORWARDED_FOR OFF, the must be ignored entirely and keying mu back to the peer address — a guard tha honouring XFF when the flag is off wou worse defect than the one being fixed. (boundary: this closes header-forgery by does not make per-IP limiting fair behin where many real users legitimately sha address. NOT CLAIMED. No change ma sites still parse leftmost; the flag still de WHAT. The rutracker SEARCH endpoint refused by bot protection while the site fully reachable. Measured unauthentica 2026-08-21 (no cookie file read, no cred value in any artifact — §11.4.10): GET / index.php -> 200, 96283 B, WHAT. download-proxy/src/api/hooks.py def _save_hooks(hooks: list[dict[str, Any None: try: os.makedirs(os.path.dirname(HOOKS_F exist_ok=True) with open(HOOKS_FILE json.dump(hooks, f, indent=2) except E as e: logger.error(f'Failed to save hooks catches EVERY exception, logs, and ret None. The signature returns None, so th has no channel to learn the write failed. sites then report success unconditionally _save_hooks(hooks) :174 _save_hooks(h logger.info('Created hook: ...') :175 logger.info('Deleted hook: ...') :156 retu HookResponse(hook_id=..., ...) :176 ret {'message': 'Hook deleted', ...} USER-V CONSEQUENCE, which is why this is H not a code-hygiene nit. A user POSTs a receives HTTP 200 and a hook_id, and t was never written — their automation s never fires, and the API told them it exi Symmetrically, a user DELETES a hook, 'Hook deleted', the file still holds it, and again after the next restart. In both dire product reports the opposite of what ha and the only trace is a log line nobody is watching. THIS IS THE §11.4.252 SHA path combines two dangerous capabilit that anchor's taxonomy — MUTATION o
BOB-173	Bug	Ready for testing	High	WHAT. The rutracker SEARCH endpoint refused by bot protection while the site fully reachable. Measured unauthentica 2026-08-21 (no cookie file read, no cred value in any artifact — §11.4.10): GET / index.php -> 200, 96283 B, WHAT. download-proxy/src/api/hooks.py def _save_hooks(hooks: list[dict[str, Any None: try: os.makedirs(os.path.dirname(HOOKS_F exist_ok=True) with open(HOOKS_FILE json.dump(hooks, f, indent=2) except E as e: logger.error(f'Failed to save hooks catches EVERY exception, logs, and ret None. The signature returns None, so th has no channel to learn the write failed. sites then report success unconditionally _save_hooks(hooks) :174 _save_hooks(h logger.info('Created hook: ...') :175 logger.info('Deleted hook: ...') :156 retu HookResponse(hook_id=..., ...) :176 ret {'message': 'Hook deleted', ...} USER-V CONSEQUENCE, which is why this is H not a code-hygiene nit. A user POSTs a receives HTTP 200 and a hook_id, and t was never written — their automation s never fires, and the API told them it exi Symmetrically, a user DELETES a hook, 'Hook deleted', the file still holds it, and again after the next restart. In both dire product reports the opposite of what ha and the only trace is a log line nobody is watching. THIS IS THE §11.4.252 SHA path combines two dangerous capabilit that anchor's taxonomy — MUTATION o

ATM ID	Type	Status	Severity	Description
				resource (a filesystem write) and EXTERNAL SIDE EFFECT (hooks are outbound calls; the system will or will not make) — so it is not to FAIL CLOSED: verify the precondition when it cannot be satisfied, and surface refusal. Instead it fails open, and a bare Exception:’ that only logs is the exact and §11.4.252 enumerates. At the product level also a §11.4.201(6) false-null: a success and a swallowed failure are indistinguishable to the caller. PROVENANCE. Surfaced as a scope observation by the independent review of the BOB-135 test-isolation work — this is what turned that defect into an ‘assertion’ mystery, because the EACCES on /config was logged and discarded while the endpoint was returning 200. Verified here directly from before filing (the function body and both reads above), not taken on report. Recorded in §11.4.238 discovery-channel escape: found in agent reading code during an unrelated investigation, not by the automated QA. The coverage gap is a defect of equal stature to the defect itself. ACCEPTANCE. (a) _save propagates failure — raise, or return a success; callers must consume. (b) Both endpoints must translate a persistence failure into an HTTP 500-class, never a success body; a creation that did not persist must not return a hook. (c) The test drives each endpoint with the hook on unwritable (read-only dir or a patched directory raising OSError) and asserts a non-2xx response AND that a subsequent GET does not list the phantom hook — assert on the user-observable outcome, not on the log line. (d) Paired mutation: restore the swallow; the test must FAIL. (e) Audit the same file for sibling files — this is a pattern, and one instance is sufficient alone. (f) Honest boundary: this does not mean the write currently fails in production; it means that WHEN it fails the user is told the outcome and the BOB-135 investigation shows it failed in at least one real environment. NOT CLOSURE. No change made. No assessment of how the write fails in the operator’s deployment. RECORDING A SHELL ERROR OF MY OWN (§11.4.6): the first version of this description was written with the anti-pattern snippet inside backticks in a double-quoted shell argument, and the shell ran it as command substitution.

ATM ID	Type	Status	Severity	Description
BOB-174	Bug	In progress	High	text was replaced by nothing — the stor description read ‘and is the exact anti-p This is the SECOND time this session th backticks-inside-double-quotes has corr content (the first mangled a commit me Fixed here by editing through a Python with no shell quoting in the path. Noted a silently-truncated defect description i the kind of quiet corruption \$11.4.201(7 about — the path is part of the instrume failed without erroring. WHAT. A corrupt hooks file is silently indistinguishable from “no hooks config and the next create then DESTROYS ev existing hook while returning HTTP 200 defects on one path, filed together beca any one alone leaves the data loss reach — download-proxy/src/api/hooks.py:104 _load_hooks wraps the read in except Ex logger.error(...) and falls through to re truncated or malformed hooks.json is th reported to every caller as an empty, he list. Confirmed at source. A2 — the cons and the reason this is High. create_hook appends, saves. Given a corrupt file tha turns into [], the save writes a one-elem over the top. Every previously-configured gone. Measured by the implementing ag against the ALREADY-FIXED tree, so th the BOB-173 write-failure fix: BEFORE ['prod-hook-0', 'prod-hook-1', 'prod-hoo reports : 200 {'hooks': [], 'count': 0} <- ZERO hooks configured DELETE report {'detail': 'Hook not found'} <- for a hoo in the file POST reports : 200 hook_id=3c8a5930-... AFTER on disk : ['3c8a5930-...'] Three prod hooks destro HTTP 200 throughout, nothing surfaced user. A5 — _save_hooks writes with a pl open(path, "w"). A crash, ENOSPC, or a write truncates the file in place. That is the corruption A1 then reads as “no hoo A2 overwrites. The same codebase alrea the correct pattern: theme_state.py:115 tmp-file + os.replace. WHY THE THREE ONE ITEM. A5 manufactures the corrup misreads it as empty, A2 destroys the co Fixing only A1 leaves truncation reacha only A5 leaves an existing corrupt file a trigger; fixing only A2 leaves the API lyi

ATM ID	Type	Status	Severity	Description
				what is configured. The chain is the def DELIBERATELY NOT FIXED UNDER BO and the reasoning is sound. The implem agent identified all three while auditing swallows as that item required, and dec fix them in the same change because: th change GET semantics on an endpoint t frontend consumes (200 -> 5xx); they n CORRUPT-file reproduction rather than UNWRITABLE-file one BOB-173 built; a need a design decision that is genuinely obvious — a MISSING hooks file legitim means “no hooks configured”, while a C one does not, and today’s code cannot t apart. Expanding BOB-173’s scope to co would have meant shipping that decisio unexamined. ACCEPTANCE. (a) Disting MISSING from CORRUPT: a missing file an empty list; a corrupt one is an error, silently []. (b) Decide and RECORD wha does on corruption — 5xx, or 200 with a degraded marker the frontend can rend the design decision, and it should be sta rather than inferred from whatever the happens to do. (c) create/delete MUST overwrite a file they could not parse — not clobber (§11.4.252: mutation plus e side effect must fail closed). (d) Make th atomic via tmp + os.replace, reusing theme_state.py’s existing pattern rather inventing it (§11.4.28). (e) Tests assertin USER-OBSERVABLE outcome, not log l a corrupt file, assert GET does not claim hooks, assert a create refuses rather th destroying, and assert the file still holds original hooks afterwards. (f) Paired §1. mutation per guard. (g) NEGATIVE COM (§11.4.201(1)): a MISSING file must stil empty list and a working create; a VALI must behave exactly as today. A fix that every load fail closed by failing always i A3, RECORDED SEPARATELY, NOT PAR THIS CHAIN. VALID_EVENTS and HookEventType are two sources of truth. closed set. Verified identical today, ungu against drift: if they diverge a hook regi successfully and then silently never fire assertion pinning them would close it. M CLAIMED. No change made. The BOB-1 failure fix is real and orthogonal — it m

ATM ID	Type	Status	Severity	Description
				FAILED write honest; it does nothing about the SUCCESSFUL write of wrong data derived from a misread file. WHAT. The workable-items update seams to violate the status-location invariant in one direction. After BOB-166, update --status <terminal> the Issues-located row is refused. The mirror image of open: update --location Fixed --status <terminal> exits 0 and creates a row that the own validator immediately rejects. Verified empirically by the independent reviewer. BOB-166: update -location Fixed -status <terminal> progress' -> exit 0 validate -> FAILS, not a row (check (f), fixedLocationNonTerminal). So the command can still mint a state it can't validate call refuses. That is the §11.4.1.1 shape at the seam layer: the invariant is NOT CONFIGURED in validate but not ENFORCED in every write path that can violate it. WHY? DELIBERATELY LEFT OPEN IN BOB-166. That's why that was right. Three reasons, all correct rather than asserted: (1) the real corpus has ZERO instances of this direction against the direction BOB-166 closed — the asymmetry the data matched the asymmetry in the detective coverage ALREADY existed and the demonstrably fires, so unlike BOB-166's this cannot rot silently; (3) and the load is one — reopenCmd documents and SANCTIONED transient Fixed-plus-non-terminal state location Fixed operator override. A naive preventive guard at the update seam would collide with that override's semantics. Correcting this therefore requires a design decision on how the two interact, which is a different question from the one BOB-166 was solved by answer, and expanding that item would have meant shipping the decision unexamined. ACCEPTANCE. (a) Decide and RECORD a preventive guard on this direction coexisting with reopenCmd's sanctioned override — this is actual work, and the answer should be verified down rather than inferred from whatever the patch does. Candidates worth weighing the reopen path explicitly, require an override flag on update mirroring reopen's, or leave the direction detective-only with the rationale recorded so the asymmetry is a decision rather than an oversight. (b) If a guard lands, it's terminalStatuses() — BOB-166 establishes
BOB-175	Task	Queued	Low	

ATM ID	Type	Status	Severity	Description
				predicate source specifically so the two cannot drift. (c) Paired §1.1 mutation. (c) NEGATIVE CONTROL (§11.4.201(1)), and sharp one here: the sanctioned reopen MUST still work. A guard that breaks reopenCmd's documented override is a positive refusal, and worse than the gap because it breaks a workflow operators to use. HONEST BOUNDARY. This is no data defect. Zero corpus instances, and detective gate catches it at the next val. filed so a scoped, deliberate omission st as a tracked decision instead of living o code comment where the next reader w it for an oversight (§11.4.197: a started reaches a documented terminal state, n abandonment). PROVENANCE. Raised l implementing agent of BOB-166 as a kn asymmetry it deliberately did not close, independently verified and endorsed as acceptable scope boundary by that item reviewer, on the condition that it becom tracked item rather than a comment. Th item. WHAT. _get_enabled_trackers() in down proxy/src/merge_service/search.py gate rutracker on RUTRACKER_USERNAME RUTRACKER_PASSWORD only. It never RUTRACKER_COOKIES. So an operator configured with cookies alone — no use password — never has rutracker enable and the tracker is silently absent from e out rather than failing visibly. WHY THA INCOHERENT WITH THE REST OF TH _search_rutracker treats COOKIES as th PREFERRED auth path, not a fallback. A nnmclub sibling DOES check its own * variable. So the same codebase holds th positions at once: cookies preferred at t site, cookies ignored at the enablement cookies honoured for a sibling tracker. V MATTERS MORE THAN IT LOOKS. CLA documents a standing operator mandat (2026-08-15) that per-tracker Netscape files at \${TRACKER_COOKIE_DIR}/ cookies_<tracker>.txt are auto-loaded i as <TRACKER>_COOKIES before every up, restart, install Stage 6 and start.sh and rutracker is named in that set. So t SANCTIONED, documented configurati
BOB-176	Bug	Queued	Medium	

ATM ID	Type	Status	Severity	Description
				for this tracker produces exactly the state the gate ignores. An operator who follows the documented instructions gets a tracker that never runs, with no error to explain it. It is in MODE. Silent absence, not a visible failure. The same §11.4.201(6) false-null shape as BOB-172 one layer earlier. BOB-172 fixes a tracker that RAN and was REFUSED being reported as if this is a tracker that never ran at all, and the merged result simply has one fewer component with nothing to indicate it. PROVENANCE is by the BOB-172 implementing agent who is tracing the enablement path to locate the handling defect. Recorded here rather than in that change: it is a separate defect on a separate seam with its own oracle, and BOB-172 in would have widened BOB-172 past it. Evidence. ACCEPTANCE. (a) The enablement gate honours RUTRACKER_COOKIES as an independently sufficient credential, matching what _search_rutracker already prefers to the nnmclub sibling already does. (b) A fix asserting that a cookies-only configuration ENABLES rutracker, driving the real _get_enabled_trackers rather than a repeated Paired §1.1 mutation restoring the user's password-only gate — the test must go to NEGATIVE CONTROL (§11.4.201(1)): a configuration with NO credentials at all leave rutracker DISABLED. A fix that erases an unauthenticated tracker is worse than the one because it produces failing searches instead of absent ones. (c) Audit the other tracker for the same asymmetry rather than fixing the one that was noticed — three positions in the codebase suggests nobody has checked them together (§11.4.118). HONEST BOUNDARY verified against a live cookies-only deployment read from source by the BOB-172 agent and recorded on its report. The reading is syntactically checkable, but whoever takes this should check by invocation before relying on it. BOB-172 Bug Queued High WHAT: BOB-172 fixes an identical 4-line HTTP-refusal guard at file private-tracker fetch sites in download-merge_service/search.py (rutracker cookie :rutracker credential :1468, kinozal :164, nnmclub :1761, iptorrents :1934). Only rutracker COOKIE path is exercised by EVIDENCE (reviewer-authored mutation)

ATM ID	Type	Status	Severity	Description
				11.4.194(6)(d), during the BOB-172 independent review): deleting ONLY the kinozal guard (search.py:1655-1658) while leaving the rest intact left the full merge service suite as passed, ZERO failures. The suite cannot pass at any of the five sites. FAILING SCENARIO: a guard that drops or subtly breaks the wiring at kinozal, nnmclub, iptorrents, or rutracker-credentials. The test fails with a 403 at that site silently folds back to status=empty with error=None -- the expected BOB-172 signature -- and no test reddens. DIRECTION (reviewer preferred): collapse the five duplicated wirings into one shared function, e.g. _check_search_response(tracker_name, status, body) -> bool, so there is ONE check and a sixth site cannot be added unguarded. (11.4.251 byte-identical-fork extraction). Alternative: parametrise the guard tests to run at all five sites with per-site stub sessions. ACCEPTANCE: mutating the wiring at A to fail at five sites reddens at least one test. Provided for running the same R1 deletion at each site. BOB-178 Bug Queued Medium WHAT: the download-proxy/src/merge_service/search.py:1638-1640 handles a failed kinozal LOGIN response with if login_resp.status in (200, 301, 302): logger.error(...); return True; else: sets NO diagnostic. FAILING SCENARIO: Cloudflare returns 403 on takelogin.php, and the kinozal chip reads status=empty, error=BOB-172. That is the BOB-172 signature exactly: a 403 is reported to the user as an empty result. CONTRAST establishing this is an oversight is a design choice: the rutracker and nnmclub failures DO set diagnostics (upstream_check_auth_failure), and the iptorrents login fails through to the search fetch where BOB-172 guard catches it. Kinozal is the one leg that fails neither. FIX DIRECTION: stash _classify_upstream_http_status(login_response.status) before the early return, or an auth_failure for the status-in-(200,301,302)-but-no-check case. ACCEPTANCE: a stubbed 403 on the kinozal login endpoint produces a non-Malicious on the kinozal chip, with a RED capture of the pre-fix code first (11.4.115). BOB-179 Task Queued Medium WHAT: the BOB-179 independent review demonstrated two failure paths that still report a refusing or unrecognised tracker as an empty result. Both are PR

ATM ID	Type	Status	Severity	Description
				EXISTING and neither is a regression fix. BOB-172, but the fix evidence log presents five-site coverage without stating the body (11.4.194(5) requires un-analysed dimensions, explicit gaps, never silently assumed safe -- exception before resp.status is read. In probe B, captured: a connection-refused error, rutracker yields status=empty, error=None, http_status=None, metadata.errors=[], metadata.status=completed. Each _search method swallows exceptions (except Exception, logger.error; return results) before _search error handling can see them, so a trackback DOWN is indistinguishable from one that is genuinely empty. GAP B -- soft refusal at 200. Reviewer probe A, captured: _classify_upstream_http_status(200, <body>) returns None, which is CORRECT design (a 2xx is a usable response; body triggering would risk the over-fire the network controls exist to prevent). But all five searches use aiohttp's default allow_redirects=True, session-expiry 302 -> login-page-200 change to zero rows and reports empty. FIX DIFFERENTIAL: Gap A needs the exception to reach a diagnostic rather than being swallowed. Gap B needs a DISTINCT detector (final-URL check or form marker) with its own RED -- explicit widening of the status-code trigger. ACCEPTANCE: both gaps closed with the REDs, or explicitly closed per 11.4.112 evidence. Immediate sub-task: append a gaps paragraph to docs/qa/BOB-172/fix_evidence_20260822.log. BOB-180 Queued Low WHAT: download-proxy/routes.py:727-745 sets status=captcha with a hardcoded message naming RuTracker 'RuTracker requires CAPTCHA. Use /api/rutracker/captcha'. FAILING SCENARIO: search returns zero results and the captcha flavoured diagnostic came from NNMCI Turnstile, not RuTracker. The user is told a RuTracker captcha endpoint for an NNMCI problem. SEVERITY BOUNDED: the full and tracker_stats travel in the same response payload, so the truth is present and a client reads them is not misled -- only the header is wrong. The branch was revived by BOB-180 error propagation (correctly: suppressing error propagation would recreate the same failure).

ATM ID	Type	Status	Severity	Description
				one layer up, 11.4.247) and is already c the routes layer by tests/unit/api_layer/ test_routes_coverage.py:782. FIX DIRE derive the message from the tracker(s) actually erred rather than hardcoding o SCOPE NOTE: api/ was owned by a sibl stream during BOB-172; the author was not to touch it. ACCEPTANCE: an NNM captcha diagnostic on a zero-result sear produces a headline naming NNMClub. BOB-181 Bug Queued High WHAT generate_markdown_exports.sh accepts arguments. It unconditionally scans PROJECT_ROOT/*.md, docs/ recursively scripts/ recursively (scan loops at lines 105/111/116 as of 2026-08-23; they wer when this was filed — line numbers shif the BOB-169 fix, the substance is uncha was independently verified by execution the generator with an explicit path prod out-of-scope export and NOT the request and PROJECT_ROOT is derived from BASH_SOURCE (line 17). A caller who v 'bash scripts/generate_markdown_expor docs/qa/SOME/file.md' gets a WHOLE-T with the argument silently discarded. W MATTERS: the caller reasonably believe was scoped to one file. It was not. In a s checkout with parallel work streams thi regenerates any export whose .md is ne its derived files anywhere in the tree -- artifacts in other streams' scopes and, v BOB-068 auto-commit hazard, into anot stream's commit. CLASS: a false afforda script's interface implies a capability it have (11.4.201: an interface must mean claims). FIX DIRECTION: either accept path arguments and honour them (scop run to exactly those files), or REFUSE v clear message when arguments are pas Silently discarding them is the one opti must not remain. ACCEPTANCE: passin either scopes the run to it, or exits non- naming the unsupported argument. A R capturing today's silent-discard behavio (11.4.115). LIVE INSTANCE, MEASURE 2026-08-23 (this is no longer hypotheti During the BOB-169 fix the conductor i the generator with an explicit path to re ONE document. The argument was disc

ATM ID	Type	Status	Severity	Description
BOB-182	Task	In progress	Medium	the whole tree was scanned. It generated qa/BOB-174/DESIGN_DECISION.{html, at 11:50 -- a SIBLING_STREAM's document that stream's author was still editing the (.md mtime 12:00). The exports were the stale on arrival, and additionally carried fix BOB-169 charset defect. The sibling independently reported them as stale in hand-off, having no idea another stream created them. SECOND-ORDER LESSON keeping with this item: the conductor's verify the blast radius ALSO failed, and silently. 'git status --porcelain grep -E pdf)\$"' returned only its own files and a clean - but docs/qa/BOB-174/ is an UNT DIRECTORY, which porcelain collapses line, so the grep was structurally incapable seeing the files inside it (11.4.201(7)(a) the wrong surface; the quiet zero read a absence). The instrument that DOES see OPERATOR DECISION (2026-08-26, interactive clarification): KEEP THE MONOTONE RATCHET §11.4.224(E) adoption answer, recorded as consumer the adoption model for CM-EXPORT-CH VALID is the MONOTONE-DECREASE I The count may only go down, never up. Immediate hard floor, changed-code-only deadline, and per-corpus phase-in were offered and NOT chosen. This closes half BOB-182 — the half that was genuinely operator's. THE REMAINING HALF IS A DEFECT STILL OWED: BASELINE is a constant, so the ratchet does not actually — on improvement the gate PASSES and the value to lower it to, but nothing lower the gate keeps permitting regression back original count after the corpus heals. THE NOT collapse §11.4.249 role separation that writes its own threshold during a p run becomes a PRODUCER as well as a Acceptable shapes include a persisted b the gate READS but never writes with l via a separate explicitly-invoked comma gate that FAILS loudly when the live count below baseline so drift becomes an action refusal. This answer is recorded as consumer DATA per §11.4.35 — it is the operator's choice, not an agent inference, and sup any prior agent-chosen default on this q

ATM ID	Type	Status	Severity	Description
				Options not chosen are named above so reader does not re-litigate a settled call (§11.4.112(5) bounded-verdict disciplining to decisions). — prior item text follows - CM-EXPORT-CHARSET-VALID (pre-build 50) adopts its 301 pre-existing violation monotone-decrease ratchet rather than floor. Two things are owed. (1) THE ADOPTION DECISION IS THE OPERATOR'S, NOT THE SCRIPT'S. 11.4.224(E) requires the broad adoption question be SURFACED to the operator and the answer recorded as consumer I never an invented ratchet. What exists is a header comment plus a BOBA_EXPORT_CHARSET_BASELINE constant that DOCUMENTS a decision the agent does not RECORD an answer the operator. The independent reviewer judged the change defensible and would not reverse it (a history on 301 violations makes the build unreasonable which 11.4.234 forbids; 11.4.101 favours a reversible option) but correctly held that it is yet compliant. Options for the operator: immediate hard floor (BASELINE=0) / keep monotone ratchet / per-corpus phase-in / changed-code-only with a scheduled full deadline. (2) THE RATCHET DOES NOT ACTUALLY RATCHET. BASELINE is a hard constant. On improvement the gate PASSES PRINTS the value to lower it to, but not lowers it, so the gate keeps permitting it all the way back to 301 after the corpus. The header now says tightening is MANUAL rather than claiming automatic behavior does not exist (11.4.6), but the honest stop is a stopgap, not the fix. WHY IT WAS NOT WITH THE FIX: a gate that writes its own threshold during a pre-build run becomes PRODUCER as well as a GATE (11.4.24 separation), and that is a design change the operator should approve rather than record as side effect. ACCEPTANCE: the operator adoption answer recorded as consumer I and either a persisted baseline the gate never raises (with the role-separation question answered), or an explicit decision manual tightening is acceptable.
BOB-184	Task	Queued	Medium	Three icon-glyph controls (.bridge-retry toggle, .caret) render text made of non-points. axe-core declines to decide their

ATM ID	Type	Status	Severity	Description
BOB-185	Task	Queued	Medium	reporting them under the incomplete class with messageKey nonBmp and resolving NEITHER fgColor NOR bgColor, so the recomputation in docs/qa/BOB-164/axe_contrast_scan.py cannot decide either such nodes across 16 palette x mode combinations. BOB-164 round 2 stopped being scored as silent passes by naming GLYPH_UNMEASURED, printing them on run and fencing them, so any NEW unmeasured glyph node blocks. What remains genuine is their contrast itself: as non-contrast interface components they owe 3:1 under SC 1.4.11, and no oracle in this repo measures that today. Acceptance: a measurement that resolves the effective foreground and background for glyph controls (for example reading getComputedStyle colour against the computed backdrop, or replacing the glyphs with a carrying explicit fill tokens), each of the controls shown to clear 3:1 in all 16 palette mode combinations, and the GLYPH_UNMEASURED fence shrunk by the nodes then proven. docs/qa/BOB-164/axe_contrast_scan.py static dist with no backend, so every node's existence depends on fetched data is absent from the page it measures: the results table remains empty, so .type-badge and .quality-badge never appear, and the hooks list renders empty so .status pills never appear. That is precisely why the BOB-164 round-1 regression was unseen in a rendered DOM even though scanned in all 16 themes, and it is why I had to close the class in the arithmetic class instead. Those nodes are now covered by frontend/src/app/models/style-contrast.py which extracts declared foreground-on-background from the stylesheets, but that is an ARITHMETIC claim about declared colour pairs, not a rendered-pixel one: it cannot see opacity by an ancestor, a composited backdrop, or cascade this repo's static extractor does not model. Acceptance: the scan drives the dashboard with seeded fixture data (a seeded backend, a route fixture, or an injected component harness) so the badge and status nodes are present in the DOM, axe measures them directly, and a control needle proves

ATM ID	Type	Status	Severity	Description
BOB-187	Bug	In progress	—	rendered oracle sees a seeded sub-floor before any clean result from it is believed. scripts/ownership_precondition.sh cons SAME unreviewed .env-driven scope as ownership_repair.sh and creates probe it, but it is NOT fenced. T028 remediation ownership_path_fence() to scripts/lib/ownership.sh and wired it into ownership_repair.sh, closing the path-es class there; the precondition was outside agents file scope and still accepts whatever config/owned_paths.yaml expands to. B is lower than a recursive chown (it writes files rather than mutating ownership of existing tree) but the INPUT is identical, equally unreviewed, so the same QBITTORRENT_DATA_DIR value that will drive a filesystem-wide chown will drive file creation at an arbitrary location. No escape is empirically confirmed for the path, not merely reasoned: during T028 remediation a probe declaring the verbatim shipped entry with QBITTORRENT_DATA hung the suite, and ps showed the real executing “find / (! -uid 1000 -o ! -gid 1 -printf ...” before it was killed by verification. Acceptance: ownership_precondition.sh SAME ownership_path_fence() predicate scripts/lib/ownership.sh (never a second 11.4.251), refuses fail-closed on a rejection and ships a paired 1.1 mutation proving refusal fires PLUS a negative control proving six live shipped entries still ACCEPT so not a 11.4.201(1) false-positive refusal. Discovered out-of-band during T028 remediation and reported by the agent as needing tracking; it is also a 11.4.238 coverage escape. OPERATOR DECISION (2026-08-26, interactive clarification): UNTRACKED BINARY — BUILD ON DEMAND §11. answer, recorded as consumer DATA: the compiled workable-items binary is NOT tracked. ‘Any build derivate which we can recreate by executing proper mechanisms generating MUST NOT be versioned’ applies without exception here. Keeping it tracked only the invariant-52 fingerprint gate, and keeping it tracked with a commit-time record were both offered and NOT chosen. RE
BOB-188	Bug	In progress	—	

ATM ID	Type	Status	Severity	Description
				END STATE: the gate builds from source REFUSES HONESTLY when the Go tool absent (§11.4.201(11) — probe the artifact through its real invocation path, never fail pass, never silently fall back to a stale h Staleness becomes structurally impossi than merely detected. ACCEPTED COST clone needs a Go toolchain before invar can run — already true for the qBitTorre backend, so this adds no new host requ The invariant-52 fingerprint gate remain as defence-in-depth for as long as any b exists on disk. This answer is recorded a consumer DATA per §11.4.35 — it is the operator’s stated choice, not an agent in and supersedes any prior agent-chosen this question. Options not chosen are na above so a future reader does not re-liti settled call (§11.4.112(5) bounded-verdi discipline applied to decisions). — prior follows — pre_build_verification.sh inva (CM-WORKABLE-ITEMS-VALIDATE) res binary through the candidate loop at :5 FIRST entry is constitution/scripts/work items/bin/workable-items. That file is G TRACKED (md5 17644a248363, identic workable-items-linux) and executable, s resolution over the current untracked s constitution/scripts/workable-items/wor items (md5 43376a6d0184). The tracke STALE: it does not contain the guards it source now has. MEASURED, needle-pr 2026-08-25. String presence in the trac binary: “refusing to set terminal status” “Issues-location item has TERMINAL st control needle from the SAME updateC least one mutable field flag is required” the instrument sees through that path a zeros are real absences, not a blind rea untracked sibling returns 1 / 1 / 2 for th three queries. A check whose message : absent from the binary cannot fire. RUN PROOF: the same injected violation (a r terminal status while current_location= run through both binaries -> stale repo violation (only the body_md desync clas reports 2 including the location-status c verbatim. This is exactly why the ten BC rows (BOB-087/129/131/144/145/146/148/15

ATM ID	Type	Status	Severity	Description
BOB-189	Bug	Queued	—	survived undetected: the gate that was to catch them was running a binary structure incapable of seeing them. The 11.4.108 >ARTIFACT gap: source correct, artifact every gate reading the artifact reports of This is the THIRD instance of that class one session, alongside BOB-169 (a character that never opened a file) and BOB-183 (a bundle five days older than its sources). COMPOUNDING: the comment at :519- directly above the loop asserts “The naïve workable-items path never existed in the checkout (bin/ is a gitignored local build dir nothing ever populated)”. That state is now FALSE - bin/ holds two tracked binaries, a stale comment asserting the absence of a file that now shadows resolution is how it stayed invisible. Also an 11.4.30 question: who owns: bin/workable-items and workable-items-linux are VERSIONED BY ARTIFACTS in a constitution submodule inherited by reference by every consumer; every consumer inherits whichever binary was last committed. Flagged independently by separate agents this session. ACCEPTABLE resolution must never prefer a stale artifact over a current one - either the tracked binary is removed and resolution falls through to demand, or a freshness check refuses a binary older than its sources (see the BOB-183 fingerprint gate for a working pattern); (c) the false comment at :519-523 corrected; (c) the 1.1 mutation proving the new refusal fix is a negative control proving a genuinely fresh fix still passes so the fix is not an 11.4.2010 positive refusal; (d) the 11.4.30 tracked decision recorded as operator DATA. Discovered out-of-band during BOB-166 remediation 11.4.238 coverage escape in its own right. WHAT: the fail-open scanner’s shape-(A) heuristic cannot distinguish ‘return False’ meaning PROCEED-AS-IF-FINE from ‘return False’ meaning REFUSE. It flags six text CLOSED guards as fail-open defects: <code>_is_safe_fetch_url (x3)</code>, <code>_qbit_add_success</code> and the <code>hooks</code> path-boundary guard. INDEPENDENTLY VERIFIED 2026-08-2 conductor rather than taken on the trial word: <code>download-proxy/src/api/routes.py</code> defines <code>_is_safe_fetch_url</code> returning <code>bool</code>

ATM ID	Type	Status	Severity	Description
BOB-191	Bug	Queued	—	only call site at :1476 reads 'if not _is_safe_fetch_url(url): logger.warning(I SSRF-unsafe download URL (non-public skipping); continue' - a False return RE the URL. WHY THIS MATTERS: per §11.1 a false-positive refusal is a FAIL-bluff of severity to a false-negative pass, and he consequence is worse than noise - actin finding would mean making the SSRF g returning False, i.e. deleting an SSRF p to satisfy a gate. A gate that instructs y remove a security control is actively dan not merely imprecise. REPRO: run the f scan; observe six hits; read each call sit ACCEPTANCE: the scanner distinguishes shaped from proceed-shaped False retu site-aware, or an audited waiver list wit entry justification), the six drop out, AN golden-FALSE fixture containing a real guard is added so the discrimination is falsifiable per §1.1. WHAT: the §11.4.252 fail-open scan rep for qBitTorrent-go, and that zero is NOT evidence. The triage agent ran control n through the scanner's own path per §11.1 (b): a Python 'except Exception: pass' n SEEN, a TypeScript 'catch (e) {}' needl SEEN (so frontend/src's zero IS a real z Go empty-'if err != nil {}' needle was N An instrument that cannot see the idiom the same quiet zero as a clean tree, and of those is honest. DISTINCT FROM BO deliberately not merged with it per §11.1 BOB-189 is a false MATCH (fail-closed q reported as fail-open); this is a false NU entire language unscanned). Same scan opposite failure directions, different fix merging them would hide one behind th IMPACT: Go is the language of qbittorre go and boba-jackett (port 7189, which c encrypted tracker credentials), so the u surface is exactly where §11.4.252's cre plus-mutation combination is most likel has assessed it; the dashboard says clea ACCEPTANCE: the scanner grows a Go covering the empty-err-block and swallo idioms, its needle is SEEN through the qBitTorrent-go's result is re-derived, an finding is triaged as this Python/TS pass Until then qBitTorrent-go's fail-open po

ATM ID	Type	Status	Severity	Description
				UNKNOWN and must be reported as UNKNOWN never as 0. === ROUND-2 INVESTIGATION MEASURED 2026-08-26 — THE FILED WAS TOO NARROW (§11.4.6) === The scanner is constitution/scripts/gates/cm_dangerous_combination_fail_closed_per-root by invariant 39 at scripts/pre_build_verification.sh:1481-1544. (scripts/pre_build/check_cm_no_fail_open_skip.s NEVER existed on any branch — it exists in an uncommitted worktree. Any citation of path is citing a file that is not there.) IT IS A WEAK-MATCHER DEFECT, NOT A SCOPE DEFECT. Line :243 sets exts=“py go rs c cc cpp h cs js ts jsx tsx php rb” — .go IS enumerated line :537 gates the Python ast analyser “\$f” in *.py), so every non-Python file falls through to just two text matchers (:772 catch (...) {, :794 credential = x \\ ‘ Go has no catch keyword, so neither matches fire on Go by construction. NEEDLE TEST ARMS (planted / rc / result): Python 2 / TypeScript 1 / 1 / SEEN · Java 1 / 1 / SEEN · 6 / 0 / NOT SEEN — PASS · Rust 2 / 0 / SEEN · Ruby 1 / 0 / NOT SEEN · C 2 / 0 / SEEN. Go is ONE OF FIVE BLIND EXTENSIONS not a special case. The Go needle is ready build rc=0, go vet rc=0, gofmt -e clean. DECISIVE DISCRIMINATOR — same by extension changed: .zig (NOT enumerated) “SKIP — topology_unsupported”; .go (enumerated) → “PASS”. The gate ALREADY OWNS an honest-blindness mechanism and works correctly; Go routes around it precisely BEING ENUMERATED. A scope hole and itself; this matcher hole prints green. This is the worse defect and is why the correct leads with it. QUANTIFIED SURFACE (as stated, §11.4.224(E)): using the scanner to prune list and nothing added — 106 .go 20,389 LOC (52 production files / 6,858 WITH and WITHOUT exclusions the count == 106; no vendored tree exists, so no exclusion could manufacture a clean number qBitTorrent-go holds 106 blind files and analysable files — 100% blind — yet invent counts it among “5 first-party source reported clean. DEFECTS THE BLINDNESS → filed as BOB-204 (credential DELETE unconditional 204 while the .env plainte

ATM ID	Type	Status	Severity	Description
				error is discarded; plus the env_write_failed_db_rolled_back code as an unconfirmed rollback). SEPARATE S HOLE → filed as BOB-205 (cmd/boba-ct orchestrator, absent from DANGER_RO entirely). Distinct-but-similar per §11.4. deliberately not merged. GOLDEN-FALS FIXTURE FOR ANY FUTURE GO ARM: jackettapi/auth_middleware.go:45-66 is fail-CLOSED (constant-time compare, 401+return) — a Go arm MUST NOT fla LOAD-BEARING §11.4.250 PREDICTIO a naive Go regex arm on will IMMEDIAT manufacture BOB-189-class false positio — if err != nil { return false } in a G is fail-CLOSED. Fixing this as layer N+1 reproduces BOB-189 in a new language THEREFORE the remediation order is f analyser REGISTRY with an UNANALYS verdict FIRST — extension→analyser m unmapped extension reports UNANALYS never silent PASS, which converts the fa into an honest gap and covers rust/ruby only then a Go arm, call-site-aware from (go/ast, or adopt errcheck/staticcheck r hand-rolled regex), shipped with the auth_middleware golden-FALSE. ONE PRIMITIVE, TWO SYMPTOMS: the scan classifies by local syntactic shape and n consults semantic role — BOB-189 igno CALLER's context (false match), BOB-1 searches for a shape from a DIFFEREN language family (false null). The gate's header already concedes the primitive (r real data-flow analysis this gate CANNOT honestly claim"); what is missing is prop that concession into PER-LANGUAGE h Keep two tracker items. INSTRUMENT RECORDED, NOT HIDDEN (§11.4.201(investigation's first verdict extraction u -oE 'PASS\ FAIL\ SKIP', which matched l inside the gate's own name (...FAIL-CLC mislabelled three PASSes. Re-run keyed code; the table above is the corrected r EVIDENCE: docs/qa/BOB-191/ scanner_blindness_investigation_20260 (255 lines, §11.4.44 header). No source config modified by the investigation. WHAT: the BOB-161 gate lands with 6 r open skips RATCHETED rather than fix
BOB-192	Task	Queued	—	

ATM ID	Type	Status	Severity	Description
BOB-193	Bug	Queued	—	Ratcheting is the constitution's named l default (§11.4.135/§11.4.224(E)) and th own precedent, so the choice is correct remediation it defers is real work that n owned somewhere. WHY THIS ITEM EX gate's own header asserted the 6 were SEPARATELY (§11.4.197)' while no trac existed. The §11.4.209 independent rev verified the absence and raised it as IMPORTANT-5, noting that without a ro findings are precisely the parked-unver class §11.4.226(4) names - the populatio operator samples and finds broken. A p of being tracked is not tracking. WHAT NEEDS: a skip that fires on evidence th ANSWERED must either classify the res and FAIL on it, or take a §11.4.69 reaso honestly derivable from the environmen than from the response - verified agains stack, not asserted. Two of the six sit un allow-skip:' markers at tests/unit/ test_tracker_auth_live.py:105 and :108, reviewer confirmed genuinely are fail-o that marker must not be treated as abs ACCEPTANCE: all 6 remediated with R evidence per §11.4.115, the gate's BASI ratcheted to 0, and the ratchet's monoto decreasing property preserved through (§11.4.227(A)). NOTE the reviewer's MI count-baseline absorbs a one-out-one-in remediation progress must be checked the finding SET, not only the count. WHAT: in download-proxy/src/api/stream the dedup set is written BEFORE the yi seen_hashes.add() / seen_hashes_local.a execute at :317 and :356 ahead of emitt format_event raises, the result is never its hash is already recorded, so it is per dropped. Independently verified by the reviewer at both sites: mid-search the h persists across subsequent polls so the never re-emits; at completion the stream immediately after, so there is no later cl either. Results later in the SAME batch yet added and do re-emit on the next po is why the observed symptom is partial rather than total. WHY IT IS FILED SEF the §11.4.252 fail-open pass made this l OBSERVABLE by adding a log line, whic right first move — but observability is n

ATM ID	Type	Status	Severity	Description
BOB-194	Bug	In progress	—	The underlying at-most-once semantics and per §11.4.226(5) a mitigation cannot the defect it mitigates. THE DECISION TRADE, not an oversight to correct blind moving to add-after-successful-yield given least-once, but a DETERMINISTIC serial failure would then retry the same result poll forever — trading silent loss for a h Options are (a) keep at-most-once and t log line as the contract, (b) add-after-su yield with a bounded per-hash retry buo add-before-yield but remove the hash on failure so exactly one retry occurs. ACCEPTANCE: an explicit decision reco implemented, and covered by a test tha raising emit and asserts the chosen sem with a RED observed first per §11.4.115 as MINOR-1 by the independent review fail-open batch; filed rather than absorb residual defect is not retired along with logging that revealed it. WHAT: agent worktrees under .claude/v are ephemeral copies pinned at arbitrar - never built, never shipped, deleted wh agent finishes. Pre-build gates that walk with find(1) from the repo root descend anyway. MEASURED INSTANCE (2026-CM-GO-TOOLCHAIN-MATCHES-BUILD FAILED the main build with exactly one from .claude/worktrees/agent-afda1df90 - a worktree 86 commits behind still can 'FROM golang:1.23-alpine' against a go since at 1.26.2. The main tree was COR throughout. Per §11.4.201(1) a false-pos refusal is a FAIL-bluff of equal severity pass: it blocks real work and teaches pe bypass the gate. FIXED FOR ONE GATE added to that gate's PRUNE_DIRS with deterministic §1.1 pair - a stale mismatch inside .claude/worktrees must NOT fail tree, the SAME mismatch outside it MU fail, so the prune cannot widen into blind (§11.4.201(6)). Mutation verified: revert prune fails 2 checks. SURVEY, measure inferred: 8 of 13 pre_build gates walk th only the fixed one prunes .claude. Gates ls-files' are structurally immune - workt untracked. Empirically probed: check_cm_closure_seam_binds, check_cm_killpg_pgid_guard and

ATM ID	Type	Status	Severity	Description
BOB-195	Bug	In progress	—	check_cm_no_production_mutation_resi rc=0 with ZERO worktree references - c practice today. UNMEASURED, not clea check_cm_test_mock_pid_explicit_int an check_cm_test_mock_pid_patched_when were not reached before the probe bud expired. HYPOTHESIS REFUTED, recor nobody re-walks it: an earlier revision o speculated that check_cm_plugin_count timeout was caused by walking worktre NOT. That gate's find is scoped to \$PLU (check_cm_plugin_count.sh:224), so wo are outside its walk entirely. Its slownes still running past 54s on a re-measure - different, still-unidentified cause and be its own item, not this one. ACCEPTANC tree-walking gate either prunes agent s is proven immune by measurement, eac paired mutation. NOTE the asymmetry bounds the risk: a stale worktree can on findings to a security-relevant scan (kill mutation-residue), never remove them - exposure is false refusal and eroded tru missed defect. OPERATOR DECISION (2026-08-26, interactive clarification): TEACH TH SCANNER With NODES — KEEP SIM \$11.4.252 fail-open scanner is FIXED to contextlib.suppress; ruff's SIM105 rule ENABLED in pyproject.toml. Disabling and the belt-and-braces both-at-once op offered and NOT chosen. Rationale carr the decision: fixing the gate makes SIM harmless, whereas disabling SIM105 al leave the gate blind to any suppress wr hand, inherited from a dependency's sty already present in the tree. REQUIRED BEHAVIOUR: with contextlib.suppress(with suppress(...)) (the from contextlib suppress binding) wrapping a dangerous combination call are DETECTED with th severity and message shape as the try/e pass form; a narrow suppress(SpecificEr around a NON-dangerous call must NO since a false-positive refusal is a \$11.4.2 FAIL-bluff of equal severity to a missed CONSEQUENCE FOR THE NUMBER: c landed, the scanner's finding count stop floor over try/except shapes and becom genuine census — any prior count citing

ATM ID	Type	Status	Severity	Description
				completeness was scoped to try/except answer is recorded as consumer DATA p §11.4.35 — it is the operator’s stated ch an agent inference, and supersedes any agent-chosen default on this question. C not chosen are named above so a future does not re-litigate a settled call (§11.4. bounded-verdict discipline applied to de — prior item text follows — WHAT: the fail-open scanner matches Try-handler s (A1)/(A2). contextlib.suppress is a With swallow written that way is invisible. VI BY THE CONDUCTOR with a control ne through the same invocation path (§11.4. (b)), because a first attempt returned 0 forms and was itself blind - the gate tak not a positional, so a bare path exits on unknown arg (§11.4.201(7)(c): the invoc is part of the instrument). Correct run: pass around os.unlink(user_supplied_pa ‘FAIL - swallowed exception ... :5’, the m sees. contextlib.suppress(Exception) are IDENTICAL call -> ‘PASS - no swallowe exception ... anti-patterns found’. Both untrusted input with an irreversible unl swallow everything; one is caught and c WHY IT IS WORSE THAN A PLAIN GAP pyproject.toml enables ruff’s SIM rules SIM105 is ‘use contextlib.suppress inste except-pass’. Our own linter therefore i authors to rewrite the form this gate CA into the form it CANNOT. The two tools pulling in opposite directions and the li runs more often. Every SIM105 autofix shrinks this gate’s coverage while the c down, which reads as progress. CONSE FOR THE NUMBER: the scanner’s findi is a FLOOR over try/except shapes, not of swallows. Any statement of the form open sites remain’ must be read as ‘N a except shapes’. ACCEPTANCE: the scar recognises contextlib.suppress (a With v items call contextlib.suppress with a br exception type) and applies the same ≥ capability test; a golden-TRUE fixture in form; a golden-FALSE fixture where sup wraps a single-capability diagnostic em must NOT fire; and an explicit decision SIM105 tension - either exempt the sha gate governs, or accept suppress and te

ATM ID	Type	Status	Severity	Description
BOB-196	Task	Queued	—	gate to read it. Discovered by the §11.4 remediation agent when its own MINOR required using contextlib.suppress at the diagnostic-emitter sites; those three use legitimate and justified in-source. WHAT: the CM-PLUGIN-COUNT pre-bu takes 189 SECONDS to verify 8 documents. Measured 2026-08-25: exceeded probe budget (rc=124), then a bounded completed at 'rc=0 wall=189s' - it PASS simply slow. CAUSE, MEASURED NOT GUESSED: the marker loop at check_cm_plugin_count.sh:273-290 iter EVERY LINE of every governed document spawns a pipeline per line. Per iteration grep -oE wc -l tr -d' (4 processes) plus sed -n' (2) = ~6. Governed docs are AG 689 + CLAUDE.md 494 + docs/features Status.md 670 = 1853 lines, so ~11,118 spawns, measuring ~102 ms/line. Class line-subprocess shell trap. THE IRONY PRESERVING, because it explains why simplified it: the in-code comment shows -l' was chosen DELIBERATELY over 'grep measuring the §11.4.201(12) footgun - c host (ugrep 7.8.4) 'grep -coE' returned level but 1 inside a 'set -euo pipefail' su context-dependent reading. The correct right and must be kept; it is the PER-LI application of it that costs the three min HYPOTHESIS REFUTED, recorded so n walks it: this is NOT worktree traversal gate's find is scoped to \$PLUGINS_DIR the five agent worktrees are outside its That guess was raised on BOB-194 and LIKELY FIX (unverified, stated as a can a conclusion): pre-filter with ONE grep containing 'CM-PLUGIN-COUNT:' before the loop, reducing ~1853 iterations to t lines that carry a marker, while leaving line parsing logic - and its footgun-avoid completely unchanged. WHY IT MATTE beyond impatience: this gate is on the p critical path, and CLAUDE.md leans on mechanical authority for the three disti rosters (43 curated / 43 engines / 12 bo whose conflation was BOB-149. A gate s enough to tempt anyone into skipping it nothing. ACCEPTANCE: runtime reduce counts and the footgun-avoiding parse p

ATM ID	Type	Status	Severity	Description
BOB-197	Bug	In progress	—	byte-for-byte in behaviour, proven by the paired mutation still biting plus a before wall-clock recorded. §11.4.6: nothing he questions the gate's VERDICTS - only it OPERATOR DECISION (2026-08-26, §11.4.66): GENERATE THE TOKEN A IT The conductor generates a 32-byte r token and writes BOBA_API_TOKEN into operator configures clients with it. DON 2026-08-26: token generated via secrets.token_hex(32), appended to .env comment naming BOB-197 and the route env-gating fact, chmod 600, value shown operator ONCE and never written to an file. Safety verified BEFORE writing (§1 §11.4.10): .env matched .gitignore:27 '* was untracked (needle-proven — the sa matcher confirmed docker-compose.yml tracked, so the negative is real); a §9.2 backup was taken and is itself ignored; re-check confirmed .env still ignored an from git status. Pre-store audit found th tracked BOBA_API_TOKEN= occurrence docker-compose passthrough \$ {BOBA_API_TOKEN:-} and prose in the challenge — no literal value has ever be committed. STILL OWED, and the item until it lands: the BOOT-TIME INVARIANT (§11.4.254) that refuses to start LAN-bc the token is unset or empty. Without it t is a state fix, not a defect fix — §11.4.22 explicit that a state-only repair cannot c defect item. Options not chosen: operat themselves with the invariant blocking invariant warns first and blocks on a na Recorded as consumer DATA per §11.4. operator's stated choice, not an agent in Options not chosen are named so a futu does not re-litigate a settled call. --- prio text follows --- OPERATOR DECISION (2026-08-26): arm BOBA_API_TOKEN a 0.0.0.0, backed by a BOOT-TIME invaria refuses to start LAN-bound with the tok This item IS that invariant. MEASURED inference. download-proxy/src/api/route require_api_token() reads BOBA_API_TO request time and returns immediately w or empty. Its own docstring states it pla "BOBA_API_TOKEN unset/empty -> ret (OPEN). This is the DEFAULT and prese

ATM ID	Type	Status	Severity	Description
				current no-auth contract + dev workflow docker-compose.yml:237 passes BOBA_API_TOKEN=\${BOBA_API_TOKEN} the container inherits empty unless the declares it. The operator .env does NOT it, needle-verified per 11.4.201(7)(b): the matcher hit QBITTORRENT_DATA_DIR same file, so the miss is a real absence a blind read. The qbittorrent-proxy contains RUNNING and LAN-bound at measurement Consequence: the ten routes the BOB-102 resolves as auth-wired are open in practice default deploy. WHY A STATIC GATE CAN COVER THIS. The BOB-102 gate asserts route WIRING - that a Depends(require_api_token) marker exists handler, decorator or router. It cannot a runtime ARMING, which depends on an read per request. Claiming the static gate it would be exactly the bluff the gate expects prevent (11.4.262: machine evidence missing the layer it claims). This is a boot-time issue class per 11.4.254. ACCEPTANCE: a boot-time check that, when the listener is LAN-bound loopback), refuses to start with a non-zero and a named cause if BOBA_API_TOKEN is or empty, so the open state becomes UNREACHABLE rather than the default 1.1 mutation: remove the check, prove that starts LAN-bound-and-open. Golden-FALLBACK 11.4.201(1): a loopback-bound listener with token unset must NOT be refused, or the becomes a false-positive refusal blocking legitimate dev work. 11.4.238 COVERAGE ESCAPE NOTE: found by a subagent re-exposed source during BOB-102 guard construction by the automated QA regime - which is defect class 11.4.238 names. The boot-time IS the new automated check that would have caught it. OPERATOR DECISION (2026-08-26, 11:46 AM) §11.4.66): REFUSE TO START LAN-BOUND The Go profile gets a boot-time guard: boot-time loopback only, or refuse to start. It does not auth middleware in this cycle. Rationale: the with the decision: the profile is opt-in via go, was not running when measured, and for development — so closing the exposure a guard rather than a parity implementation Options not chosen: write auth middleware
BOB-198	Bug	Queued	—	

ATM ID	Type	Status	Severity	Description
				parity with the Python route set (real w would partially un-defer BOB-101); doc dev-only with no guard (rejected — notl enforce it, and the next -profile go run c network silently re-opens 22 routes). ACCEPTANCE: a boot-time check that n the listener's bind address and refuses when it is not loopback, with a paired \$ mutation proving the check FAILs on a bind, and a golden-FALSE proving a loo bind is NOT refused (§11.4.201(1)). Sco reminder recorded so it is not lost: this covered by BOB-101's parity deferral, w about ports; folding it in would be a §11 verdict leak. Recorded as consumer DA §11.4.35 — the operator's stated choice agent inference. Options not chosen are a future reader does not re-litigate a se — prior item text follows — MEASURED conductor-verified independently of the subagent. qBitTorrent-go/cmd/qbittorre main.go registers exactly three middlew lines 62, 63 and 68: middleware.CORS, middleware.Logger, middleware.GinRat There is NO authentication middleware per-route auth dependency. main.go:11 binds addr=":" which is ALL interfaces, route is LAN-reachable when the profile SCOPE: 22 routes, of which the mutatin matter most - POST /api/v1/download, F v1/magnet, DELETE /api/v1/hooks/:id, F DELETE /api/v1/schedules. A LAN peer downloads and delete webhook configur with no credential. PARITY GAP, stated PUT /api/v1/theme is auth-gated in the l service and open in Go. The same asym holds for the download, hooks and sche mutations. Two implementations of one advertised surface disagree about whet needs a credential. RELATIONSHIP TO (Go parity deferred past v1.0.0, operato 2026-08-26): that deferral covered POR the Go container binding :7186 and :71 as :7187. It did NOT cover an authentic and the operator was not asked about o because the hole had not been measure the question was posed. Treating this as by the deferral would be a 11.4.112(5) v leak: citing a bounded decision outside its evidence supports. This item stands

ATM ID	Type	Status	Severity	Description
				and its severity is NOT settled by BOB-199. MITIGATING FACT, so severity is not overruled. the Go profile is opt-in via -profile go and is NOT running at measurement time (the list showed qbittorrent-proxy, the Python profile with no Go sibling). The exposure is late, not live. ACCEPTANCE: either auth middleware landed in the Go service with parity to the route set, or an explicit operator decision recording the Go profile as dev-only that refuses to start LAN-bound - with a guard enforcing whichever is chosen. OPERATOR DECISION (2026-08-26, §11.4.66): FLAG NARROW SUPPRESS WITH AN IRREVERSIBLE CAPABILITY scanner flags a narrow contextlib.suppress when combined with an irreversible capability (delete / truncate / kill) — the shape that causes harm. Idiomatic narrow tolerance is quiet, so the gate keeps its credibility and false-positive storm trains readers to ignore. Options not chosen: accept the asymmetry permanently with a header statement; flag narrow suppress and absorb existing sibling justified exemption list. MEASUREMENT CORRECTED TWICE, and the second correction explains the first: the original '37 narrow idiomatic' was propagated by this condition without verification, then re-measured by the authoring agent as OBSERVER. BOB-199 Task Queued — CONTAMINATION (§11.4.201(10)) — 27 vendored third-party + 9 sibling-agent v COPIES of the very tree being measured = 37. The instrument was counting other duplicates of its own subject. Reproduced figures, each with its scope stated: cons repo 0 narrow with-suppress; boba DANGER_ROOTS 0 narrow with-suppress narrow except-pass; boba repo minus vend narrow with-suppress (a suppress(OPERATION narrow except-pass RETRACTED-AND-RESTATED 2026-08-26 per 11.4.201(9)). figure 97 previously recorded here reproduced under NO scope and is withdrawn. Measurements replacements, each with its scope and independently reproduced: 34 narrow except-pass git-tracked first-party (canonical); except-pass on-disk minus scratch dirs ('minus vendored' scope this sentence stands). Brackets that explain the bad number: 8

ATM ID	Type	Status	Severity	Description
				except-pass git-tracked and 113 ALL-ex on-disk-minus-scratch straddle 97, so 97 class-scope conflation (narrow-vs-all), n corpus-scope one. The 35 cited later in record is the same measurement at git-scope and agrees with 34 within one sit 'every one idiomatic' claim was also fals except-pass census contains SystemExit unit/test_plugin_torrentscsv.py:305,328 not a benign tolerance. CORRECTION 2026-08-26: a 'KeyboardInterrupt x1' pr written in this sentence was itself unsou is WITHDRAWN — it reproduces at NEI stated scope. Independent AST count ov tracked *.py: ZERO genuine 'except KeyboardInterrupt: pass'. The only genu instance in the checkout is .worktrees/c workflows/tests/unit/test_main.py:63 — agent scratch worktree, i.e. the exact of contamination class (11.4.201(10)) this record teaches to exclude — and the on tree textual match (tests/unit/ test_graceful_shutdown.py:165) sits ins triple-quoted string literal, a carrier not (11.4.201(7)(a)). Recorded because the instructive: it was introduced BY the re that removed the 97, so a correction is : exempt from the discipline it applies. Re consumer DATA per §11.4.35 — the ope stated choice, not an agent inference. C chosen are named so a future reader do litigate a settled call. — prior item text RESIDUAL ASYMMETRY surfaced by th BOB-195 fix, reported rather than silen After teaching the scanner With nodes, suppress (Exception / BaseException) is with the same severity as try/except/pas NARROW suppress (suppress(FileNotFoundError)) is not - I semantically identical narrow try/excep FileNotFoundError: pass IS flagged. So SIM105 rewriting a narrow handler stil that site out of the gate's scope, a small of the exact mechanism BOB-195 was fi close. WHY IT WAS NOT CLOSED IN TH with the measurement that decided it: t authoring agent reported 37 narrow sup sites, all idiomatic. CORRECTION (2026 independent review): that figure DOES REPRODUCE and this conductor propa

ATM ID	Type	Status	Severity	Description
				into this item as fact without verifying - is mine, not the reviewer's. Measured: the constitution repo has 0 narrow with suppress sites; boba first-party has exactly 1 (a suppress(OSError)). The nearest corpus is 35 narrow except X: pass handlers in boba first-party - a DIFFERENT construct - and the census (OSError x7, ImportError x7, BrokenPipeError x3, RuntimeError x3, ValueError x2, FileNotFoundError x2, ImportError x2, SystemExit x2) contradicts 'every one is idiomatic': a bare SystemExit: pass is not a tolerance. The two populations must not be conflated, and the distinction is the whole substance of this item. The false-positive argument therefore rests on the 35 narrow except-handlers, not on 37 suppress sites. The strength should be re-judged on that basis. Under 11.4.201(1) is a FAIL-bluff of equal weight to the gap it would close, and worse in practice because it trains readers to ignore the gap. The subagent recorded the asymmetry in the header as a known gap rather than shipping the storm. That was the right call, and is why the separate tracked item rather than an untracked one. THE DECISION IS THE OPERATOR'S, mirroring BOB-195 itself: (a) accept the asymmetry permanently, with the gate left open, stating it so no reader mistakes the count for a census; (b) flag narrow suppress ONLY combined with an irreversible capability (e.g. truncate / kill), catching the shape that matters and leaving the 37 idiomatic sites alone; (c) flag all narrow suppress and absorb them into a justified exemption list like the LAN-reasonable-uses. RELATED FACT worth carrying: the newly-visible production sites in download/src/merge_service/search.py (1294, 1300, 1329, 1333) wrap proc.kill / os.killpg / pkill in the BOB-126 cleanup path. The condition was verified the 11.4.263 pgid guard IS present and correct at both killpg sites - _pid and _pgid - checked isinstance(int) and > 1 before the syscall, with the BOB-126 forensic reason being that it is inline - so those sites are true-by-the-scenario definition but SAFE in fact, and want a justified exemption entry rather than a code change. WHAT: scripts/gates/cm_dangerous_combination_fail_closed.py. It has its scan file list with find(1). If find itself
BOB-200	Bug	Queued	Medium	

ATM ID	Type	Status	Severity	Description
BOB-201	Bug	Queued	Medium	(permission error, resource exhaustion, interrupted), the gate receives an EMPY and interprets that as 'no files in scope' topology SKIP -> exit 0. The failure IS stderr but SILENT in the exit code, so gating on exit status reads a dead instruction clean corpus. WHY IT MATTERS: this is textbook 11.4.201(6) FALSE-NULL - a b instrument and a clean artifact return t identical quiet zero. It is also a 11.4.252 OPEN on exactly the 'cannot enumerate corpus' condition where the gate's own discipline is to fail CLOSED. A gate that see must refuse, not pass. AFFECTED S constitution/scripts/gates/cm_dangerous_combination_fail_closed.find invocation and the empty-list branch EXISTING - NOT introduced by the BO change; found by the independent round reviewer while reviewing that change a explicitly scoped OUT of its remediation REPRODUCTION: make find(1) fail during gate run (unreadable scan root, or a find returning non-zero with empty stdout) and observe the gate exit 0 with a topology-message, indistinguishable from a genuine empty corpus. ACCEPTANCE: (1) the gate distinguishes 'find succeeded and found files' from 'find failed' - check find's exit not only its output; (2) a failed enumeration FINDING (non-zero exit) naming the un precondition, never a SKIP; (3) a genuine scan root still SKIPs honestly at exit 0 - 11.4.201(1) golden-FALSE guard, so the not become a false-positive refusal; (4) mutation: restore the swallow-find-failure behaviour and the new fixture MUST fail WHAT: scripts/ownership_repair.sh fence declared scope entries LEXICALLY (stri normalisation + prefix/traversal refusal fence cannot see a symlink sitting at an INTERMEDIATE path component. A state (already-present, no race required) sym middle of an otherwise-legal declared p the recursive walk at a tree the operator declared. Measured by the T028 round-independent reviewer as surviving mutation WHY IT IS FILED SEPARATELY: the in-s honest-boundary note and Case 24 fixture this reach is 'tracked as BOB-159'. It is

ATM ID	Type	Status	Severity	Description
				VERIFIED 2026-08-26 by direct query: 1. description is 4685 chars with ZERO occurrences of 'symlink' or 'intermediate' (control-not-reachable), the body is readable through the same control path), and no item in the tracker record can reach at all. A dangling tracker citation is a real defect is recorded NOWHERE - the lost-defect shape, where the pointer loop coverage and is not. This item IS that real in-source note must now cite THIS id. SEVERITY BOUNDS, stated honestly (1) reach is BOUNDED, not arbitrary. It records an attacker or accident to have already played a symlink inside a declared scope path. It is reachable from the shipped config/owned_paths.yaml as it stands (shipped control needle: 6 rows, RC=0). It is a real widening of what a recursive chown can do, not a theoretical one - the reviewer means no race needed. WHAT THIS ITEM DOES CLAIM: that the lexical fence is broken. It does what it says - it refuses lexical escape system trees, '..' climbs) and was verified so under 12 reviewer-authored mutations, a documented LIMIT of lexical fencing, recorded as a real item instead of a citation unrelated one. ACCEPTANCE: (1) decide deliberately and record the decision - real components (realpath/-P semantics) and the resolved path, OR keep the lexical fence state the limit as an accepted operator-owned risk; the choice is operator-owned per 11.4.201(1) because resolving makes the fence depend on filesystem state at check time, which has failure modes; (2) if resolution is chosen, golden-FALSE set proving legitimate symlinks but-in-scope download roots still walk (11.4.201(1) - a fence that over-refuses the bluff of equal severity); (3) the in-source Case 24 fixture cite THIS item, not 11.4.201(1); (4) paired 1.1 mutation: restore the unresolvable behaviour and the fixture MUST fail. WHAT: scripts/ownership_repair.sh:493 parsed scope rows with 'while IFS=\$'\t' do e_path e_kind e_opt e_pres e_rec'. A scope that OMITS 'kind' emits the row ' <path>\t\t1\t0\t1'. TAB is an IFS-WHITE character in bash even when IFS is set explicitly, so a RUN of consecutive tabs is into ONE delimiter instead of delimiting
BOB-202	Bug	Queued	Medium	

ATM ID	Type	Status	Severity	Description
				field. Every field after the omission shift one. MEASURED 2026-08-26 on GNU b 5.2.37, control-needled (the with-field c run FIRST and produced output, provin instrument sees; an earlier probe of mir returned nothing for BOTH cases becau lacked a trailing newline - an 11.4.201(null I discarded rather than reported): k PRESENT: path=[P] kind=[dir] opt=[1] rec=[1] kind EMPTY: path=[P] kind=[1] pres=[1] rec=[] CONSEQUENCE: 'optio read out of 'preserve_mode's slot. An en declared 'optional: true' is therefore tre NON-optional, so an absent path that sh honestly instead becomes a hard failure 'preserve_mode'/'recursive' are likewise from the wrong slots, with 'recursive' an EMPTY. The shift is silent: no parse erro diagnostic, no refusal. REACHABILITY: reachable from the shipped config/ owned_paths.yaml - all six declared ent. 'kind' (verified). This is a latent defect in reader, not a live misbehaviour of the pr today. PROVENANCE: surfaced out-of-b the T028 round-5 remediation agent wh isolating an unrelated instrument slip, a deliberately left unfixed and unfiled by i (a) ownership_repair.sh had to stay at h ae025b74602414ca for that round's do- regress set, (b) it was outside that roun NIT remit, and (c) it had not root-caused the repair belongs in the parser, the cor the schema. That judgement was correc item is the filing it deferred. Independe measured by the conductor before filing accepted on report. 11.4.238 COVERAG ESCAPE NOTE: no automated check for was found by a human-directed agent is different problem. Per 11.4.238 the cov is itself a defect of equal standing to the closing only the bug is the violation. ACCEPTANCE: (1) root-cause the corre parser (never emit a row with an empty consumer (read with a delimiter that is whitespace, or read positionally), or sch (make 'kind' mandatory and REFUSE an lacking it, consistent with the whole-run already landed for empty expansions); t is operator-owned per 11.4.66 because the scope-file contract; (2) a fixture with

ATM ID	Type	Status	Severity	Description
				omitted 'kind' and 'optional: true' assertion entry is treated as OPTIONAL (or the reader refused), RED-first against current code golden-FALSE proving a fully-specified reader parses identically - 11.4.201(1), the reader not start refusing valid scopes; (4) paired mutation restoring the collapsing read scope fixture FAILs; (5) an automated check that have caught it, per 11.4.238. PRECEDENT FOUND 2026-08-26 (surfaced by the TC round-5 reviewer, independently verified recording): the SIBLING script scripts/ownership_precondition.sh ALREADY did this exact collapse class at lines 565-57 already ships the repair as split_tsv() at (used at 437, 699, 775). Its in-source note a real forensic measurement dated 2026 the FIRST version of that script used the collapsing read and reported "no component mounts this location" for config/ and for download root WHILE FIVE SERVICES THEM - a false statement about what was checked, produced by the instrument rather the system, which its own comment class the 11.4.201(7)(c) 'the path is part of the instrument' failure. It also records why the suite could not see it: the fixture scope compose service at all, so only running invocation against the real scope surface WHAT THAT CHANGES FOR THIS ITEM acceptance-criterion (1) 'root-cause the layer' now has a PRECEDENT rather than open design question - the consumer layer split_tsv-style reader that does not use the adopting the sibling's existing function is preferable to inventing a second dialect - two answers to one question across two that read the SAME scope rows is exact divergence that produced the round-1 'the readers of one scope file disagree' finding this is a RECURRENCE of a class already diagnosed and closed once in this codebook novel discovery - the fix landed in one round 2026-08-21 and the sibling reader kept the collapsing form, which is the 11.4.238 evidence shape at the code layer: the lesson was in a comment instead of in a check; (c) the 11.4.238 coverage-escape note above is SHARPENED - the sibling's own comment states that a fixture-scope suite cannot

ATM ID	Type	Status	Severity	Description
				class, so the required automated check exercise a row with a genuinely empty field, not merely a well-formed one. Bug Queued Critical MEASURED LIVE 2026-08-26 against the running stack from 192.168.1.90 (NOT loopback - qBittorrent localhost bypass would have exercised a code path). Evidence: docs/qa/BOB-198/runtime_auth_verification_20260826.md VERDICT: unauthenticated mutating LA requests ARE currently accepted. Two l services, four named routes: 1. POST /a torrents/stop port 7186 -> HTTP 200 w credentials (real torrent control) 2. POS hooks port 7187 -> 422 field-validation REACHED FastAPI body validation, whi AFTER middleware) 3. POST /api/v1/sch port 7187 -> 422 (same) 4. DELETE /ap hooks/<id> port 7187 -> 404 'Hook not (the handler EXECUTED A LOOKUP) TH responses are the decisive evidence, no a 401 never appears anywhere, and rea body validation or a handler lookup pro auth middleware intervened. THE ARM TOKEN IS INERT. BOBA_API_TOKEN w in .env earlier this session on an operat decision. Port 7187 returns BYTE-IDEN responses with and without it across th shapes. Port 7189 does not open for it i header shapes. Root cause identified: d compose.yml injects BOBA_API_TOKEN EXACTLY ONE service - download-proxy 237) - and into neither qbittorrent-proxy boba-jackett. And even on 7186, where injected, POST /api/v2/torrents/stop ret unauthenticated, so injection alone is n enforcement. PER-SERVICE POSTURE (measured): 7185 qbittorrent-nox LIVE, same mutating surface visible from LAN the proxy 7186 download-proxy LIVE, b 0.0.0.0 - mutating control accepted unauthenticated 7187 merge service LI 0.0.0.0 - 34 routes via openapi.json, NO layer at all 7188 bridge NOT BOUND - SKIP 7189 boba-jackett Go LIVE, binds 401-gated, reads OPEN incl. /api/v1/jac credentials 9117 jackett LIVE, binds * E service binds all interfaces. None is loop only. RELATIONSHIP TO BOB-198 (its r subject was NOT running): qbittorrent-j

ATM ID	Type	Status	Severity	Description
				profiles:-gated (opt-in --profile go) and a from the container set, so its '22 unauth routes' is neither confirmed nor refuted 11.4.3 SKIP. The exposure recorded HE DIFFERENT and ADDITIONAL surface Python service and the proxy. Do not tre item as closing BOB-198. 11.4.238 COV ESCAPE - first class, equal standing to t the automated QA regime did NOT find static gate check_cm_lan_routes_authen went through SIX independent review r proving routes are statically wired to au middleware, and its own honest bounda (tracked BOB-197) states it asserts stat ONLY. Nobody had measured runtime u directed agent did. This is precisely the covenant's founding failure shape: a gre over a broken-for-the-user reality. The o remedy is an automated runtime check would have caught it, with a RED captu exact exposure - not merely a fix to the ANTI-BLUFF PROVENANCE: control ne Jackett returned a real 401 through the instrument, so the 200s are not instrum blindness; port 7188 returned exit-7, so are real. Negative control - a deliberate token still got 401 on 7189. Decisive pr deterministic. Mutating probes used no ids against a provably EMPTY torrent li before and after), so effect was nil and v both sides. Token referenced by name o printed (11.4.10); the report was leak-s with a needle proving the scanner fires known leak. ACCEPTANCE: (1) operator (11.4.66) on the intended posture per s loopback-only bind, real auth middlewa accepted-LAN-risk-with-rationale; (2) w is chosen, an automated runtime check 11.4.238 that fails RED against today's (3) 11.4.108 layer-3/4 evidence on a cle deployment, not static analysis; (4) pair mutation. === RELATED MEASUREMI 2026-08-26 — A THIRD LAN-BOUND PO (§11.4.6, recorded not merged) === Th covers unauthenticated mutating routes and 7189. A separate triage stream mea and the conductor verified, that port 71 ALSO LAN-bound: webui-bridge.py:447 ThreadingHTTPServer((" ", BRIDGE_PO empty host string is INADDR_ANY, so it

ATM ID	Type	Status	Severity	Description
				ALL INTERFACES rather than loopback merged into this item per §11.4.214 (dis similar): this is a BIND-SCOPE fact about different service, not a demonstrated unauthenticated mutating route on 7188. Whether 7188 exposes mutating routes authentication is UNVERIFIED and is the question this note raises. Recorded here 7188 surface is not overlooked when the scope is settled — and so nobody later "it as new. BOB-204 Bug Queued c WHAT: internal/jackettapi/credentials.go (boba-jackett, port 7189). The DELETE handler checks the DB delete, then disc errors of BOTH ` _ = envfile.Delete(...)` and ` _ = d.Jackett.DeleteIndexer(id)` (li then returns an UNCONDITIONAL 204 Content. If the .env delete fails, the plain credential variables REMAIN ON DISK API reports the credential deleted. Seco instance, same file: credentials.go:166-3 returns the error code `env_write_failed_db_rolled_back` while rollback's OWN error is discarded (` _ = and :171) — the response body asserts that was never confirmed, a §11.4 bluff contract itself. SCOPE: 4 combined dan capabilities on one path (credential acc filesystem mutation + external side effe irreversible delete) where §11.4.252 fail on-dangerous-combination requires only Composes §11.4.10 (credentials must ne — a credential the operator believes de on disk, IS the leak class) and §11.4.252 REPRODUCTION: read the cited lines; t discard is syntactic and unconditional. A repro drives DELETE with the .env path unwritable (chmod 0444 or a directory-deny) and observes 204 while the variab persists in .env. WHY IT WAS NOT CAU CM-DANGEROUS-COMBINATION-FAIL gate (constitution/scripts/gates/cm_dangerous_combination_fail_closed enumerates .go at line 243 but gates its analyser on *.py at line 537, so Go falls text matchers that key on `catch` — a k Go does not have. All 106 .go files are s unanalysable while being counted as an That blindness is BOB-191; this item is DEFECT it hid. ACCEPTANCE: (1) both

ATM ID	Type	Status	Severity	Description
				sites either handle the error or the handler returns a non-2xx naming the unresolved precondition per §11.4.252(2); (2) the <code>env_write_failed_db_rolled_back</code> code is emitted when the rollback actually succeeds else a distinct honest code; (3) a RED test the unwritable-.env path and observes the 204, flips GREEN post-fix (§11.4.115); (4) golden-FALSE fixture proves the new golden not refuse the healthy path (§11.4.201(1) DISCOVERY CHANNEL (§11.4.238): found agent reading source during the BOB-1 investigation, NOT by the automated QA — this is itself a coverage escape and Bob carries the escape audit. === VERIFICATION COMPLETE 2026-08-26 — BOTH DEFECTS CONFIRMED, RED AUTHORED AND WORKING FAIL === Line numbers re-derived, NOT from the filing: :234-237 DB delete check on error) · :240-244 envfile.Delete error DISCARDED · :249 DeleteIndexer error DISCARDED · :253 unconditional 204. MISTAKE OVERSIGHT — THE GODOC BLESSES :210-211 reads: ".env and Jackett delete best-effort ...; failures are silently swallowed 204 status reflects DB success." Any fix delete that sentence or it will read as another defect (§11.4.120 — the doc asserting behaviour is part of what must be reconstructed MEASURED END STATE when the .env fails: DB row GONE, plaintext RUTRACKER_USERNAME/RUTRACKER_PASSWORD STILL ON DISK says 204. WORSE THAN THIS ITEM ORIGINALLY FRAMED IT: the ENCRYPTED canonical copy is destroyed while the Plaintext copy survives UNMANAGED — the system record of the credential is gone, so nothing ever clean it up. DEFECT (2) IS WORSE THAN FILED — CHECKING THE ERROR WOULD FIX THE LIE. The rollback calls Repo.Upsert(ifSet(prior.Username), ...); ifSet("") returns repos/credentials.go Upsert maps nil to COALESCE(excluded.username_enc, username_enc) = LEAVE_UNCHANGED the prior row had an empty field and the request set one, the compensating Upsert nil — it SUCCEEDS — and leaves the row in place. The DB is not rolled back, then error to check, and the API asserts a row

ATM ID	Type	Status	Severity	Description
				anyway. Verified live by the third RED c means defect (2) is NOT one-line-ish: it repo surface to express "set this field ba NULL" (delete-and-reinsert the prior ro state in Upsert). Scope it separately fro (1). THE RED: qBitTorrent-go/internal/j bob204_failclosed_test.go (297 lines, NI gofmt clean, deliberately isolated from credentials_test.go so it cannot widen th T042 diff). Failure injection is REAL, no envfile.mutate writes through <path>.t test pre-creates that path as a DIRECTO os.OpenFile returns EISDIR (errno 21 p envfile.Delete fails WHILE .env stays by identical with the credential in it. Chose chmod deliberately: opening a directory writing fails for root too, whereas a chm mechanism would silently no-op under u turn the RED into a FALSE GREEN. A C NEEDLE inside breakEnvWrites calls th envfile.Delete and t.Fatal's if it unexpect succeeds — a blind instrument cannot p conclusion. Measured: 3 FAIL (all three cases) + 1 PASS (the §11.4.201(1) golde proving the REDs are not tautological a the fix must not refuse the healthy path Package-wide exactly 3 failures, all this zero skips. §11.4.10 honoured: no asser message prints a credential VALUE — n booleans only, fixtures are fake-not-a-re HONEST BOUNDARY (§11.4.6): the GR of the flip is OWED, NOT CLAIMED. Th was forbidden from editing credentials. RED was watched, GREEN was not. TH SCOPED (not applied): defect (1) IS one twice — replace the two ` _ = ` with che errors returning 5xx naming the unreso precondition (env_delete_failed, jackson_cascade_delete_failed) and DEL :210-211 GoDoc sentence. Defect (2) is surface change, separate scope. ADJAC FINDINGS: (a) credentials.go is strictly than its own sibling — indexers.go:207- handles the identical DeleteIndexer erro least LOGS it; credentials.go:249 does n log. Same package, same call, two stand Repo is a concrete *repos.Credentials, n interface, so a rollback-FAILURE path c driven deterministically — relevant to § §11.4.241 if the fix wants that path test

ATM ID	Type	Status	Severity	Description
				The .gitignore false-null that nearly ate deliverable is filed separately. SPOT-CH the discards this item called benign — CONFIRMED BENIGN: client.go:140,15 resp.Body.Close() closes a body already discarded before a retry; runs.go:112 w.Write(...) is post-WriteHeader, same credentials.go:274. Bonus: runs.go:43 json.Unmarshal(...) is benign but mildly a corrupt ErrorsJSON silently reports error_count=0, documented as deliberate degradation in its GoDoc. Cosmetic und not an integrity issue; recorded so it is investigated. BOB-205 Bug Queue WHAT: the §11.4.252 fail-closed scanner per-root by invariant 39 at scripts/pre_build_verification.sh:1481-1544 over maintained DANGER_ROOTS list. cmd — 4 files, 947 LOC — is NOT in that list never scanned by any arm. It is the conductor: a shell-exec plus state-mu surface, precisely the §11.4.252 danger combination class the gate exists for. DI FROM BOB-191: BOB-191 is a MATCH (the root IS scanned; the Go files inside structurally unanalysable while counted analysed — a false null that prints green a SCOPE hole (the root is not scanned a Different failure shapes, different fixes; §11.4.214 they are distinct-but-similar, deliberately not merged. WHY BOTH EX root list is hand-maintained, so a new fi root joins the tree without joining the g §11.4.251 (role-as-data-pack) points at t direction — replace the hand-maintaine a declared manifest derived from the sa of truth the build uses, so a root cannot without being enumerated. ACCEPTAN cmd/boba-ctl is scanned — either by bei to DANGER_ROOTS or by the manifest it; (2) whichever is chosen, a RED fixtur planted fail-open inside cmd/boba-ctl is pre-fix-absent / post-fix-present (§11.4.1 the manifest route is taken, a fixture pr NEWLY-ADDED first-party root is picked without a hand edit — that is the invaria stops this recurring; (4) the honest-blind (§11.4.3 SKIP-with-reason, which the ga implements correctly for unenumerated extensions) is preserved, never convert

ATM ID	Type	Status	Severity	Description
				silent PASS. DISCOVERY CHANNEL (§11.4.6): this item said boba-ctl is a "sh" surface. There is NO exec.Command in the array — exec is one hop away via digital.vasic.containers/pkg/compose (main.go:13). The §11.4.252 threshold is checked several times over (5 of 6 capabilities: n :34,36,95-105,121 · untrusted input :21,33,53,110,144,170,302,453-465 · cr :432-440,496-509 · external side effect :239,323,430 · irreversible :36,142) — boba-ctl re-measured: 4 tracked .go files, 947 the filed numbers hold, no drift. CORRECTION 3: the gap is not one root. ENUMERATION — 266 files in scope / 5 of scope = 66% of the gate-visible first- corpus never scanned. tests/ 324 (exclu intent but UNDECLARED) · extension/ 1 51 · challenges/ 18 · cmd/boba-ctl 4 · fro e2e+configs 5 · tools/ 1 (CONCEALS 3 HITS: plugin_update_automation.py:189 · repository ROOT 1 (CONCEALS 1 REA webui-bridge.py:295). Filed separately a ROOT-SCOPE item. boba-ctl IS a genuin §11.4.252 surface, but the hole around LATENT: main.go has no `__ = err`, no e err != nil {}`, no silent `return nil` toda

ATM ID	Type	Status	Severity	Description
				control-neededled against qBitTorrent-go/config/config.go). It hides nothing live; i guarantees a future one lands unseen. C semantic finding WAS spotted by reading authMethod()'s default branch — filed s BOB-205 != BOB-191, AND THEY COM measured, one temp root, both needles: 0 hits, py-needle 1 hit. Go-blindness independently reconfirmed (gate routes to the AST arm). The real cmd/boba-ctl DIRECTLY returns "PASS — no anti-pat found" over 947 LOC it cannot analyse. THEREFORE: fixing BOB-205 ALONE n root from never-looked-at to LOOKED-A FALSELY-GREEN — the §11.4.201(6) FA NULL, the WORSE state, because it the as covered. Both must land, and the lan hole with them. THE RED: tests/pre_build test bob205_danger_roots_scope.sh. On (§11.4.245) = METAMORPHIC + INVAF with a control needle: two BYTE-IDENT Python fail-open needles (sha equality a runtime, 8d8bd909...), one in a root tha DANGER_ROOTS (control), one in cmd/ (probe), scanner driven exactly as invar drives it. Identical input, two locations, identical verdicts — matcher/language/ version held constant so SCOPE is the c variable. Independent of the code under expectation comes from the relation, no reading DANGER_ROOTS. Shape (a) ch shape (b) included as an explicitly-label WEAKER secondary (it would pass on a entry the [[-d]] guard silently skips). CONFOUND DELIBERATELY AVOIDED needle is PYTHON, not Go — a Go need stay unseen post-fix and the RED would green, which is itself a §11.4.201(1) FAI Fixing BOB-191 will NOT turn this gree widening scope will. BLIND-INSTRUME GUARD: control needle not found -> exi ABORT, never RED. The test parses DANGER_ROOTS from the real driver s with zero edits, and never runs pre_build_verification.sh. MEASURED: (evidence docs/qa/BOB-205/red_run_liv gate sha256 c5752428...) — CONTROL "instrument PROVEN seeing", PROBE 0 GREEN polarity proof exit 0 against a S copy of the driver with the root append

ATM ID	Type	Status	Severity	Description
				driver git diff --stat empty). Determinism exit 1, 3/3 GREEN exit 0. FIX DIRECTION (assessed, not applied): §11.4.251 manifest feasible, but the source of truth matters docker-compose.yml build contexts MIS plugins/, frontend/src, cmd/boba-ctl, we bridge.py; language markers (go.mod/ package.json) MISS plugins/ and webui. ONLY derive-from-git-tracked-source-ex minus a declared §11.4.224(E) exclusion reaches every gap. The derivation must either way: if the operator keeps the ha the omission-guard is the SAME compu the only question is whether it drives th audits the list. The tests/ question (324 operator §11.4.66 decision; production- defensible but currently UNDECLARED BOB-207 Bug Queued critical WHA scripts/lib/ownership.sh:299-320 probe reads stat -c '%u' and compares against ownership_operator_uid (id -u). It NEVER '%g'. Meanwhile ownership_operator_g defined at scripts/lib/ownership.sh:50 a consumed ONLY by scripts/ ownership_repair.sh:360 — so the REPA establishes uid AND gid, while the PRECONDITION that verifies the repair checks uid ONLY. The precondition can report ok while exactly half the property repair exists to establish is wrong. MEA LIVE ON THIS HOST, UNPRIVILEGED (directory is all it takes — no loopback, n no sudo): dir: uid=1000 gid=10 mode= (chgrp wheel + chmod g+s, both unpriv real file created there: uid=1000 gid=1 probe_location verdict = ok rc=0 <-- op is 1000, file gid is 10 SEVERITY RATIO is the SAME CLASS that BOB-206 alleg probe reporting ok while ownership is c held) but on an axis that is LIVE rather hypothetical, needs no unusual filesystem reproduces with two unprivileged comm BOB-206 was dismissed; this is the real that investigation surfaced underneath ACCEPTANCE: (1) probe_location reads compares gid as well as uid, OR the asy deliberately justified in-source with the only uid matters to the user-visible goal and explain why the repair sets gid at a RED fixture builds the setgid directory

ATM ID	Type	Status	Severity	Description
				observes ok pre-fix, flips to a refusal po (\$11.4.115); (3) a golden-FALSE fixture correct uid+gid location is still ok (\$11. (4) whichever way it is resolved, precon repair agree on WHICH property they a about — that disagreement is the prim (\$11.4.250). DISCOVERY CHANNEL (\$1 found by the BOB-206 verification strea the automated QA regime. No existing t exercises a gid mismatch. === CONFIR 2026-08-26, RED AUTHORED — AND T DIRECTION IS THE OPPOSITE OF WH ITEM ASSUMED === CONFIRMATION derived against the dirty tree; line num happen to match): probe_location() at s ownership.sh:299-320 reads stat '%u' tv file branch, :314 dir branch), compares want at :301, and NEVER reads '%g'. ownership_operator_gid is defined at :5 EXACTLY ONE consumer — ownership_repair.sh:360 — verified acro tracked AND untracked files, needle-pr (needle ownership_operator_uid -> 13 f negative control -> 0; untracked sweep 8 files, ownership_operator_gid -> 0); e hit is a docs/DB carrier or comment. TH SETS GID AT TWO SITES, not one: :719 "\${OP_UID}:\${OP_GID}" WRITES both find_args selects on (! -uid OR ! -gid). REPRODUCED unprivileged (chgrp to a from id -G + chmod g+s): dir uid=1000 mode=2755, a REAL file created inside uid=1000 gid=10, probe_location verdi rc=0. Needle arm: an absent path retur 'absent' rc=1 — the probe CAN refuse, is real. DESIGN QUESTION ANSWERE **NARROW THE REPAIR. gid is NOT lo bearing.** This item was filed assuming PROBE was deficient. Measured, that is backwards. - With correct uid and gid= read, rename, move, chmod, utime, dele ALL PERMITTED — including recovery chmod 000 with NO elevation. Owner-c are selected by uid match and chmod is only, so the operator can always restore Every FR-001 / FR-002 / FR-003 / FR-01 phrased as "owned by the account". NO requirement mentions gid. - DECISIVE, conductor-verified in spec.md: the Cons section blesses "Group-based workarou

ATM ID	Type	Status	Severity	Description
BOB-210	Bug	Queued	major	(shared groups, permissive modes, access lists) are acceptable implementation requirements. Dependencies makes "shared group plus inherited permissions" NECESSARY if the container platform cannot map the in-container account to the operator's identity. => WHY THE PROBE would make FR-010 REFUSE TO START on a configuration the spec explicitly sanctions — a §11.4.201(1) false-positive. The exact failure class this project keeps in its own gates. => AND THE REPAIR IS ALREADY DOING HARM: measured, after a new file inherits gid 1000 instead of 1000, setgid bit still set and NO diagnostic. The probe silently dismantles a spec-sanctioned shared group setup. THE RED: tests/unit/test_ownership_gid_agreement.sh (NEW lines, bash -n clean). It deliberately does not assert "the probe must call stat %g" — the implementation assertion that survives the fix AND hard-wires one fix direction. It is the user-observable invariant: probe_log == ok IFF ownership_repair.sh --dry-run ZERO items under L. Measured: 4 passes failed / EXIT=1, the failure being "the PRECONDITION certifies it (ok) while the REPAIR reports it broken (selects:2)". VALIDATED AGAINST BOTH CANDIDATES from patched COPIES (production unto baseline FAIL(1) · narrow-the-repair PASS widen-the-probe PASS(0). Golden-FALSE in all three, so neither direction can go refusing everything. That is what makes fix-direction-agnostic rather than a vote FIX, NOT APPLIED — scripts/ownership_repair.sh:963: - find_args+=("\${OP_UID}" -o ! -gid "\${OP_GID}" \) - '%U\t%G\t%m\t%p\0') + find_args+=(!{OP_UID}" -printf'%U BOB-208 WHAT: scripts/ownership_precondition.sh:342-348 documents the docker branch of detect_rootless() as documented-not-measured (accurate — verbatim). The header then claims the build so that 'an unverified reading can manufacture a refusal'. IT CAN. Line :4 CONFIDENT rootful verdict whenever it succeeds with non-empty output containing name=rootless field. Only the FAILURE fall through to unknown (:387-394). THE

ATM ID	Type	Status	Severity	Description
BOB-211	Bug	Queued	minor	TO HARM: PUID=0 is declared in docker compose.yml:32 (and again for jackett - deliberate per project policy). With a rootful verdict, that reaches the R3 refusal:517. So a genuinely ROOTLESS Docker whose docker info output SHAPE differs from the documented one gets a FALSE REFUSAL produced by a branch the source itself a was never measured — precisely the outcome the header promises is impossible. THE OTHER PROBLEM (§11.4.245 independence): the tests DO cover this path (tests/unit/test_ownership_rootless_detection.sh:2) the shim's output shape was authored for SAME documentation as the code. Oracle code share the unvalidated premise, so cannot discover that the premise is wrong; confirms the code matches the doc; nob confirmed the doc matches Docker. ACCEPTANCE: (1) either the header clause corrected to match :413's real behaviour is changed to yield unknown when the measurement is unverified — the two must agree (§11.4.245) or the docker branch's premise is validated against REAL docker info output from a real rootless daemon, or the branch is honestly marked as unmeasured at the point of USE, not only in the header; (3) if validation is operator-gated (e.g. on a rootless Docker host), record it as such in the log (§11.4.21 rather than leaving the header standing. ALSO VERIFIED GOOD, record it as such; is not re-investigated: the unknown branch is handled IDENTICALLY at both consumer and producer: :519-531, R4 :832-836 — both a named measurement return 0, neither refuses), ROOTLESS_V is cached at :487 so both read ONE measurement, and the carrier-trap gold fixture EXISTS (test_ownership_rootless_detection.sh:2) drives name=rootless-lookalike inside a path and must NOT read rootless; struct guard at :396-411 uses exact field equality (substring). DISCOVERY CHANNEL (§11.4.245) found by the BOB-206 verification stream. STATUS: LATENT on this host (measurements declared locations sit on ONE btrfs mount, ownership-expressive) and OPERATOR-gated verification. Retained from the dismissal of BOB-206 rather than discarded with it, the scenario is well-founded elsewhere:

ATM ID	Type	Status	Severity	Description
				declared mount is a udisks auto-mounted REMOVABLE NVMe, so another operator portable drive being exFAT or NTFS is ordinary. TWO RESIDUALS: (1) REPAIR DIAGNOSIS. On a uid-flattening mount flattened uid is NOT the operator, probe correctly REFUSES (verified: uid=0 and uid=100999 both refuse). But it then has ownership_repair.sh a chown that will refuse EPERM, and nothing in the repair path is aware — so the operator sees a permission whose real remedy is a REMOUNT OPT which no message says. Reasoned, NOT the shim used to verify BOB-206 models READ, not the chown WRITE, and cannot whether chown actually fails. (2) MODE CONTRACT. vfat flattens MODE via fma so the preserve_mode: true / 600 contract and config/boba.db would be silently unenforceable there. §11.4.10-adjacent: credential file believed to be 600 that is readable by mount option is a leak the mount check cannot see. WHY OPERATOR-GATED genuine end-to-end RED needs a real uid flattening mount. The privilege-free route bindfs -u (FUSE; fusermount IS present user_allow_other IS set) — but bindfs is on this host, as are mkfs.vfat and losetup verification needs either a bindfs install privileged loopback mount. Neither was attempted (§11.4.21 — high-blast-radius mutation is operator-gated). ALSO RECOGNITION NO test anywhere exercises a uid-flattened filesystem — vfat/exfat/ntfs/flatten/loopback losetup/bindfs/fusermount all measure (the three ownership test files, needle-probe (probe_location = 3 hits through the same instrument). ACCEPTANCE: (1) operator whether to install bindfs or provide a privileged loopback so the RED can be built; (2) if the repair path gains fstype-aware diagnosis naming the remount remedy; (3) the mode contract either detects mode-flattening and refuses, or documents honestly that be enforced there. DISCOVERY CHANNEL (§11.4.238): retained residual from the verification stream. WHAT: .gitignore:31 is a deny-all glob <i>credentials</i>, followed by a HAND-MAIN per-file allowlist of ! exceptions (lines 3-
BOB-212	Bug	Queued	critical	

ATM ID	Type	Status	Severity	Description
				NEW source file whose name contains 'credentials' (or 'creds') is silently ignored. git add refuses it and git status shows NOT ADDED. The author gets no signal at all — the file does not exist as far as the commit path is concerned. HOW IT SURFACED: the BC stream authored a RED test named <code>credentials_failclosed_test.go</code>. It vanished. The agent noticed only because it went looking for the file it had just written. It renamed to <code>bob204_failclosed_test.go</code> to escape both <code>credentials</code> and <code>creds</code>, and the file became visible. A silent deliverable loss, caught by luck rather than by any gate. INDEPENDENTLY REPRODUCED AND CONFIRMED BY THE CONDUCTOR, confirmed by the needle proven: <code>git check-ignore -v -no-index qBitTorrent-go/internal/jackettapi/credentials_failclosed_test.go</code> -> <code>.gitignore:31:credentials (IGNORED)</code> <code>git check-ignore -v -no-index qBitTorrent-go/internal/jackettapi/zzz_probe_test.go</code> -> no match (not ignored) <- the needle: instrument provided. Seeing, so the hit above is real <code>git check-ignore -v -no-index frontend/e2e/credentials.spec.ts</code> -> <code>.gitignore:31:credentials (IGNORED)</code> <code>git check-ignore -v -no-index frontend/e2e/credentials.spec.ts</code> -> tracked SECOND INSTANCE: <code>frontend/e2e/credentials.spec.ts</code> matched by the same rule and survives because it is already tracked (git honors index over .gitignore for tracked paths) and-re-add it — an ordinary refactor, a local operation, a file move — and it disappears silently. It is one routine operation away from being lost. (For contrast, <code>credential-editor-dialog.component.spec.ts</code> is genuinely covered by the DIRECTORY rule <code>!frontend/app/jackett/credentials/</code> at line 43, not by file entry.) WHY THIS IS A §11.4.201(6) NULL, NOT MERELY AN INCONVENIENCE: a blind instrument and the clean tree return identical quiet zero. <code>git status</code> showing <code>??</code> means BOTH 'no new files' AND 'a new file but is invisible'. There is no signal that distinguishes them. The commit path — every other gate's output eventually has to get through — cannot see its own blindness. IS NOT SIMPLY 'ADD ANOTHER ! LINE' the mechanism that produced the defect. maintained allowlist against a deny-all gate.

ATM ID	Type	Status	Severity	Description
				the §11.4.251/§11.4.205 shape — every legitimate credential-named source file hand edit nobody will remember to make failure mode of forgetting is SILENT. The shape as BOB-205's hand-maintained DANGER_ROOTS: a list that must be ec lockstep with the tree, with no guard th when it was not. TENSION TO RESOLVE HONESTLY (§11.4.10 vs §11.4.201(1)): exists for a real reason — §11.4.10 forb credential material reaching git, and a l deny-all is the conservative-safe default. Narrowing it carelessly would re-open a leak channel. So the fix is NOT 'delete t Candidate directions, operator decision (§11.4.66): (a) narrow the deny to what carries secrets — extensions and direct (.env, secrets/, credentials.json yaml ym rather than every path containing the w keep the deny-all but add a GATE that F when an untracked file matches an igno AND lives under a first-party source roo a source extension, so the swallow beco instead of silent; (c) both. (b) alone clos false-null even if the glob stays exactly and is the smaller change. ACCEPTANC NEW credential-named source file unde party source root either commits norma produces a LOUD refusal naming the ru blocked it and the remedy — never silen RED that creates such a file and asserts current silence, flipping to the loud pat (§11.4.115); (3) a golden-FALSE proving secret material (a .env, a key) is STILL i the §11.4.201(1) guard, because a fix th credentials to close a false-null is strictl than the defect; (4) frontend/e2e/ credentials.spec.ts is made safe by rule than by the accident of already being tr DISCOVERY CHANNEL (§11.4.238): fou BOB-204 stream when its own delivera disappeared — NOT by the automated C and not by any gate. Nothing in the rep that an authored file actually became v git. Coverage-escape audit: no surface e this class at all. === SCOPED AND ME 2026-08-26 — RECOMMENDATION (b) IS DISPROVEN NOT MERELY DISFAVOR === TASK 1a — TRACKED FILES SUR ONLY BY BEING TRACKED: 3, not 157

ATM ID	Type	Status	Severity	Description
				sweep of all 2795 tracked paths hit 157 rules — but 154 of those are NEGATIVE (lines), i.e. explicitly re-included and safe. RULE. Reporting 157 as the blast radius; have been a §11.4.201(1) false positive; investigating stream caught this itself. 2 independent instruments (check-ignore on non-negated patterns, and bare check which emits only truly-excluded paths) IDENTICAL sets. 1. frontend/e2e/credentials.spec.ts — .gitignore:31 credentials.spec.ts (the known one, 109-line Playwright spec) 2. tests/security/test_jackett_autoconfig_secrets.py — .gitignore:51 secrets — HAZARD, NOT NAMED IN THIS ITEM WHEN FILED Conductor-verified: matched by :51, currently tracked. It is a 113-line SECURITY / PEPPER asserting no credential value reaches anywhere, body, traceback, or log. Losing it silently remove the test that guards §11.4.10 — all glob's own purpose. That is the shared instance available: the rule protecting code is one refactor away from deleting the test proves credentials are protected. 3. sub-jackett — .gitignore:260 — NOT a hazard 160000 gitlink, and that entry is documented deliberately inert for git (it steers Code §11.4.79). THE MECHANIC THAT DECIDES FIX: the directory negation at :43 re-includes DIRECTORY ONLY. A new frontend/src/jackett/credentials/credentials.guard.ts swallowed by :31, because <i>credentials</i> contains no slash and is therefore BASENAME-safe the allowlisted directory buys nothing for files. Of the 154 safe files, 124 are held robust glob negation (!docs/qa//.log) and fragile hand-maintained per-file entries 13 currently live, none stale — but expect future silent loss). TASK 1b — ALREADY SWALLOWED UNTRACKED FILES: 560,217 ignored+untracked paths. Two real losses (the tracker-credentials twins and the BOB-124 .txt evidences as their own item); set_password.py recorded UNKNOWN: provenance and deliberately NOT called lost work; d-proxy/qbittorrent_creds.json is the HAZARD CONTROL — shape-inspected keys-contains (never values) as [password, username]

ATM ID	Type	Status	Severity	Description
				<i>genuinely credential-bearing, CORRUPTED and ignored. TASK 2 — MEASURED IN A SCRATCH TREE, 10 source paths x 10 paths: baseline (full 316-line file) swallows 10 leaks 0 (a) EXACTLY AS THIS ITEM WORDED IT swallows 0 leaks 3 (a) to plug those 3 swallows 1 leaks 1 all unchanged + loud gate swallows 0 (a) LEAKS download-proxy/qbittorrent_creds.json — A REAL CREDENTIAL FILE SITTING IN THE FILE TODAY — because credentials.json does not match “creds”. It also leaks my_password and service_credentials. Repairing the file leaves service_credentials: an extension scoped deny cannot cover EXTENSIVE secret files without collapsing back to deny-all it was meant to replace. So this item worded it is DISPROVEN, not merely disfavoured — and I wrote (a) the candidate list, which was wrong (b) NEWLY ALLOWS INTO GIT: NOT the set is EMPTY. No pattern change §11.4.10-vs-§11.4.201(1) proof obligation discharges trivially. No variant of (a) make that argument. TASK 3 — THE tests/security/test_gitignore_swallow_is_loud.sh (file verified not swallowed BEFORE writing joke this item is about). It asserts the acceptance DISJUNCTION (commits normally OR refuses loudly), so it is DIRECTION-AGNOSTIC and leaves the direction an operator decision. The bearing assertion is A3: git status is IDENTICAL with and without the file A (authored) 330ceb52074cdbbe, with (never made) 330ceb52074cdbbe. The false-null proven directly, not argued NOT a tautology: RED_MODE=1 -> guard stand-in -> exit 0; narrowed guard exit 0; and the §1.1 mutation DELETE globs -> exit 2 with 11 leaks caught what makes the golden-FALSE load-rather than decorative. Exit 2 is deliberately distinct from exit 1 so a blind harner never read it as “defect present”. BLIND WHAT THIS ITEM FRAMED: it is not ntials/creds* problem. secrets, _passwords*_user* have EACH already swallowed s</i>

ATM ID	Type	Status	Severity	Description
				real.** *_user* is the broadest — it will future *_user.txt / .json evidence or fixt fix must be evaluated against the whole not the one glob that surfaced first. == SECOND LIVE TRAP HIT, SAME SESSI (2026-08-26) === The BOB-207 stream natural filename tests/unit/ test_ownership_user_owned_gid.sh for i Conductor-verified: that path is SWALL by .gitignore:60 _user. The stream chec before writing (having been warned) an renamed to test_ownership_gid_agreem which is clean. That is the SECOND del one session that the deny-all globs woul silently eaten — the first (BOB-204's credentials_failclosed_test.go) was caug after the fact. It also confirms this item "beyond the item" warning empirically: the broadest of the four globs and it cau whose name contains no secret and no c — merely the word 'user' inside 'user_o which is the FEATURE'S OWN NAME (s user-owned-downloads). Any test namee feature is a candidate for silent loss. Tw one session, from two independent stre a coincidence rate — it is the defect ope normally. WHAT: the §11.4.252 fail-closed gate's c list omits shell entirely. Measured verba conductor at constitution/scripts/gates/ cm_dangerous_combination_fail_closed. exts="\${DANGEROUS_COMBO_EXT:-p cc cpp h hpp java cs js ts jsx tsx php rb} No bash. THE CONSEQUENCE, MEASU scripts/ IS a declared DANGER ROOT (pre_build_verification.sh:1511). It conta tracked .sh files and 3 .py files. So 71 of source files in a root the gate is explicit at are SILENTLY INVISIBLE — while in 39's driver prints "no fail-open anti-patt N first-party source root(s)". Project-wid are 198 tracked .sh files (negative contr 0, instrument proven seeing). WHY THI WORST OF THE THREE HOLES: BOB-2 scope hole (root never looked at). BOB- matcher hole (Go enumerated but unan THIS one is worse than either, because IS declared, IS scanned, IS counted as c and 96% of what is in it was never exam count in the driver's own summary is ar
BOB-213	Bug	Queued	critical	

ATM ID	Type	Status	Severity	Description
				count presented as a census. AND SHE HIGHEST-RISK LANGUAGE HERE, not lowest: the project's orchestration, cred handling, container control and gates a start.sh alone is 1288 LOC and is, per CLAUDE.md, THE orchestrator. Fail-op is also unusually easy to write — a bare true`, an unchecked ` \$? , aset +eregion swallowed2>/dev/null– and §11.4.67(6) a records one live instance of exactly th (a bare exec redirection silencing an i shell for its lifetime). CORRECTION TO PREVIOUSLY-STATED ACCEPTANCE CRITERION I asserted, when filing BOB-205, that " honest-blindness path (§11.4.3 SKIP-with which the gate already implements corre unenumerated extensions) is preserved". WRONG. The gate's honest SKIP-with-reaso for the PYTHON ARM's degradations, NOT extensions absent from the ext list. An unenumerated extension is a SILENT false not an honest skip. The distinction is bearing and I stated it backwards. NOT NUMBERS: the BOB-205 stream cited the ex :318; the conductor measured it at :457 correct at their read times – a sibling (BOB-195 r7) is actively editing this f derive before acting. ACCEPTANCE: (1) c shell is added to the ext list WITH an a can actually analyse it, or unenumerated extensions produce an explicit UNANALYS per file – never a silent pass (this is analyser-registry fix BOB-191 needs, and once covers both); (2) the driver's sum reports files ANALYSED, not files presen under-count cannot masquerade as a cens RED planting a shell fail-open under sc asserting it is SEEN; (4) golden-FALSE p §11.4.201(1) – a correctly fail-CLOSED s guard must NOT be flagged; §11.4.67's ov scoped exec form is the natural fixture COMPOSES: BOB-191 (matcher hole – same p classify by local shape, never consult s role; and the analyser-registry fix clo and BOB-205 (scope hole). Per §11.4.250 three symptoms of one primitive defect; §11.4.214 they stay three items because differ. DISCOVERY CHANNEL (§11.4.238): the BOB-205 verification stream, confir independently by the conductor. Not by

ATM ID	Type	Status	Severity	Description
				automated QA regime. BOB-214 Bug critical WHAT: DANGER_ROOTS = (download src plugins scripts qBitTorrent-go from at scripts/pre_build_verification.sh:15. REPOSITORY ROOT itself is not among them (conductor-verified: no "." entry). Even living at the top level is scanned by no. THE LIVE HIT: webui-bridge.py – tracked (conductor-verified), 466 LOC, a live HTTP service on port 7188 (BaseHTTPRequestHandler.do_GET/do_POST:92-97, request path read outbound urlopen at :273, environment config read at :55-74). The gate REPORTS A REAL HIT :295 when pointed at it directly. This is a hypothetical gap: the existing gate, under test, finds a genuine defect in this file the scope reaches it. ALSO UNSCANNED AT ROOT first-party shell scripts including start.sh (1288 LOC – per CLAUDE.md the project's orchestrator and the sole sanctioned control entry point), stop.sh, ci.sh, install-plugin.sh, and the credential-handling scripts password.sh / fix-qbit-password.sh. (The latter is additionally invisible for the separate reason – shell is not in the gate's scope – so root files get missed twice over, first AND by extension.) THE SCALE THIS SITS ON: 512 files in scope / 512 out of scope – 66% gate-visible first-party corpus is never scanned. Other unscanned roots measured: tests/ (108 files, excluded-by-intent but UNDECLARED), undeclared exclusion is exactly what §11.4.224(E) fences against), extension/ (108, shipped by extension), docs/ (51), challenges/ (18), plugin_update_automation.py:189,198,215 (1, and it CONCEALS 3 REAL HITS at frontend/e2e + 2 configs (5). SO THE SCALE CONCEALS AT LEAST 4 REAL HITS the gate misses finds when pointed at them (1 in webui-bridge.py, 3 in tools/). Invariant 39's reported count is an under-count, not a census. ACCEPTANCE: repository root and tools/ are scanned, explicitly fenced with a stated reason per §11.4.224(E) – silence is not an exclusion; the 4 concealed hits are triaged (each is either a real defect to fix or a false positive in the gate – both are findings); (3) the 1 file) gets an OPERATOR decision per §11.4.224(E) production-only is defensible but must be UNDECLARED; (4) a RED proving a root-level

ATM ID	Type	Status	Severity	Description
				open is seen; (5) golden-FALSE proving (build artefacts and vendored trees stay excluded. FIX DIRECTION (measured by th stream, not guessed): a §11.4.251 manife feasible but the source of truth must be carefully – docker-compose.yml build cor MISS plugins/, frontend/src, cmd/boba-c webui-bridge.py; language markers (go.m package.json) MISS plugins/ and webui-b Only derive-from-git-tracked-source-ext minus a declared §11.4.224(E) exclusion reaches every gap. Note the derivation n built either way – if the operator pref keeping a hand list, the omission-guard audits it is the SAME computation; the question is whether it drives the scan the list. DISCOVERY CHANNEL (§11.4.238 by the BOB-205 verification stream while enumerating the full gap list – the iter verifying named only one missing root. I automated QA regime. === CORRECTION 202 THE "4 CONCEALED REAL HITS" CLAIM IN TH REFUTED (§11.4.6) === When I filed this wrote that the scope hole "conceals at real hits the gate itself finds when po them". A dedicated triage stream ran the UNMODIFIED gate against scratch copies, reproduced all four hits exactly, and t them: **4 of 4 are FALSE POSITIVES.** TI instrument was control-needle-proven in directions first (fired on a plantedexc pass, stayed silent on a clean log-and- so this is evidence, not a null. All f the SAME detector class – shape (A2) "s default return" – which is precisely the false-positive shape: the returned liter function's designed refusal value, cons caller that checks it. - webui-bridge.p (_is_root_liveness_probe): False -> send_error(502) at :438. The except DEN lenient 200 path. Fail-CLOSED. Combines the six §11.4.252 capabilities – a pure classifier over self.path/self.command. tools/...:189 (_download_url): None -> handles it explicitly (warn + continue) write. Handler BOUNDED to (URLError, HT anything else propagates. - tools/...: (_extract_version): "unknown" gates not update decision is the HASH compare at IS a bareexcept:though, so Ctrl-C is sw

ATM ID	Type	Status	Severity	Description
				a separate signal-handling defect, file README item.) - tools/...:215 (_validate_plugin): False -> :151 return the write at :165. This IS the refusal. BOB-189 shape. WHAT THIS DOES AND DOES CHANGE. The scope hole itself is UNCHANGED still real – the repository root and tool in no DANGER_ROOT, verified verbatim at pre_build_verification.sh:1511. What change the ARGUMENT: I justified this item partially hides four known defects", and that justification is wrong. The correct justification is not and does not depend on any current hit: bridge.py is a LIVE, LAN-BOUND HTTP server below) handling request paths, outbound and environment credentials – a surface belongs in scope on its capabilities, whether not it currently contains a defect. NEW RAISING THE STAKES – 7188 IS LAN-REACHABLE webui-bridge.py:447 binds ThreadingHTTPServer(("", BRIDGE_PORT)) - conductor-verified. The empty host string INADDR_ANY, so port 7188 listens on ALL INTERFACES, not loopback. Neither local nor internet-exposed (internet only if forwarded). No severity is assigned to because it is fail-closed – but this is argument for putting the root in scope: LAN-bound service should be scanned on port not after a defect is found in it. webui-bridge.py IS LIVE, DECISIVELY (§11.4.124 engages – do NOT treat it as superseded tracked files reference it, including conductor_served_ports.yaml and the credential-leak challenge; download-proxy actively probes bridge_health() at download-proxy/src/api/__init__.py:198; newest of 12 commits is functional fix (6e3da73, 2026-06-14). Conductor_served_ports.yaml:66-69 records that the webui-bridge is a SEPARATE binary the qbittorrent-proxy-go container never starts NOTHING ELSE BINDS 7188 and this Python is the only thing serving that port. tools.RECOMMENDATION (§11.4.224(E)): FENCE IT DECLARED – exclusion class "non-shipping developer utility". Evidence: 2 tracked files neither gitignored; the script is invoked NOTHING (control-needle-proven: 91 needed negative control – referenced only by its README, its own docstring, and a tracked

ATM ID	Type	Status	Severity	Description
				zero hits across *.sh/*.yaml/*.py/Makefile/tools/); its README self-declares "not the normal start/stop flow"; last function commit 2026-04-12. Because it is FIRST-§11.4.224(E) requires the exclusion can't be tracked §11.4.197 item – and the two REA found in it must be tracked regardless of since a hand-run --update still executes BOB-215 Bug Queued major WHAT boba-ctl/main.go:498-509, authMethod(). default branch (:507) returns remote.Aut A deploy-registry entry whose auth: key misspelled, empty, or set to an unrecognized value therefore resolves SILENTLY to SSH authentication rather than refusing to a IT IS A §11.4.252 VIOLATION: this is a credential-selection decision on a path performs remote mutation and external side effects. §11.4.252 requires a path combination dangerous capabilities to FAIL CLOSED – every precondition, refuse when any is unverifiable, and name the unresolved precondition. Silently substituting a default credential MECHANISM for an unreadable declaration is the textbook fail-open strategy operator's intent was not determined, and code proceeded anyway using a method they have chosen. WHY NO GATE CAUGHT IT: three independent reasons, each sufficient on (a) cmd/boba-ctl is in no DANGER_ROOT (b) even in scope, .go files are structurally unanalysable by the current gate (BOB-19 this shape is a semantic default-branch not one of the two text patterns the normal arms match. It was found by a human-equivalent read, which is precisely the §11.4.238 of class. HONEST QUALIFICATION (§11.4.6): boba-ctl/main.go has NO_ = err, NO emptyif err { }, and NO silentreturn niltoday – grep with a control needle against qBittorrent/internal/config/config.go. This finding is an exception, not one of many; the scope here boba-ctl is otherwise LATENT (it hides rather else live, it guarantees a future one later unseen). ACCEPTANCE: (1) an unrecognized auth: value REFUSES with an error naming the offending key and its declared value, not silently defaults; (2) a RED driving a auth: and asserting today's silent SSH-key resolution, flipping to refusal post-failure

ATM ID	Type	Status	Severity	Description
				golden-FALSE proving every LEGITIMATE and still resolves correctly – a false refusal would break real deploys (§11.4.201(1)) DISCOVERY CHANNEL (§11.4.238): found by BOB-205 verification stream while configuring boba-ctl qualifies as a §11.4.252 surface BOB-216 Bug Queued major WHAT: carrier classes fire in the gate's PRIMA not only its degraded text fallback. Meas ast_rc=1 AND text_rc=1 (both modes reported hit): (a) a COMMENT or DOCSTRING quoting credential anti-pattern is reported as a credential default – both spellings; (b) comment or a string constant holdingtry catch (e) { }is reported as an empty catch per carrier line. Shape (b), and the C-half of shape (a), are LANGUAGE-AGNOSTIC with NO structural counterpart in any mode there is no parser to be immune. WHY IT the gate's header carried a blanket class parser is immune to both by construction is OVER-BROAD and now corrected in place to the Python Try/With shapes where it is actually true. Everything else – every extension, and the credential/empty-catch matchers even on Python – has no AST arm so the immunity never applied there. A §11.4.201(1) false refusal in the PRIMA materially worse than one in a fallback expects to be exact: it refuses provably code on the path the gate is trusted on CONTROL NEEDLE THAT SHARPENS IT (recorded next reader inherits the measurement): a COMMENTED import does NOT poison the line table (text=0), because those regexes are anchored. So the blindness is to STRINGS specifically, not to non-code generally distinction is what makes the comment-strip tractable for one class and not for the WHY IT WAS NOT FIXED IN THE ROUND THAT (§11.4.6 honest boundary, and this is the call): closing these needs a PER-LANGUAGE comment-and-string model across every extension. That model's failure directed UNDER-reporting one – a mis-parsed string silently swallows real violations for the remainder of the file. The same reasoning the round DECLINE the triple-quote fence for OVER-1 while ACCEPTING the comment OVER-A: the comment strip's ambiguity re

ATM ID	Type	Status	Severity	Description
				toward KEEPING text (proven by three com needles – real violation + comment, # in string, escaped quote before # – all 1/2 whereas a fence counter's ambiguity res toward DROPPING text. Direction of failu difficulty, is the discriminator. Build lexer here would import the under-repor failure mode this gate refuses everywher OPERATOR DECISION (§11.4.66 / §11.4.197 to build per-language comment-and-string is a consumer call, not a default this g should pick unilaterally. Options: (a) a over-reports and DISCLOSE them per clas the round did – a new MODE-INDEPENDENT section now enumerates all three); (b) h models per language and own the under-re with a fixture per language; (c) narrow language-agnostic greps so they only fi structural arm exists, trading coverage precision. RELATION TO SIBLINGS (§11.4 distinct-but-similar, deliberately not r BOB-189 is the gate flagging a fail-CLOS guard – a semantic-role miss in the PYTH This is a CARRIER miss (comment/string code) that is MODE-INDEPENDENT. BOB-213 language absent from the ext list entire three share the primitive §11.4.250 name BOB-191: classify by local syntactic sha consult semantic role – but the fixes d the items stay separate. ACCEPTANCE: (1) operator decision above is taken and rec (2) whichever path is chosen, each of th classes has a fixture proving current be so a future change cannot silently alter if (b) is chosen, a golden-FALSE per lan proving a REAL violation adjacent to a c still caught – the under-report guard, v the whole risk. DISCOVERY CHANNEL (§11 found by the BOB-195 round-7 remediation while closing a different finding, NOT h automated QA regime and NOT by the inde reviewer that audited the same file in r BOB-217 Bug Queued critical WH tools/plugin_update_automation.py update combines three §11.4.252 dangerous capab and is gated by nothing that could stop payload: - UNTRUSTED INPUT: 14 URLs ac GitHub repositories, THREE of which are party PERSONAL repos, not the official qbittorrent organisation. - MUTATION: v

ATM ID	Type	Status	Severity	Description
				plugins/<name>.py. - DEFERRED CODE EXECUTION qBittorrent EXECUTES those engine files bytes fetched over the network become runnable code on the operator's host. The ONLY vulnerability is compile(content, "<string>", "exec") plugin_update_automation.py:213 – conduct verified as the sole compile call. That SYNTAX check. A syntactically valid file exactly what a hostile payload is. There signature verification, NO pinned commit hash allowlist, NO provenance check of a §11.4.252 requires a path combining >=2 capabilities to FAIL CLOSED – verify even precondition, refuse when any is unverifi This path combines THREE and verifies none them. §11.4.246's supply-chain clause is direct counterpart: dependencies are either vendored hash-verified, provenance-attested mirrored through a hash-pinning registry unattested public source is an integrity and here the unattested public source be EXECUTED CODE. THE SHARPEST FACT ABOUT FINDING: the fail-closed gate produced FALSE POSITIVES in this same file (:189 :215 – all triaged FALSE POSITIVE, see correction) while MISSING this, the one dangerous combination in it. That is the §11.4.201 both-directions failure – false positive and false-negative – demonstrated a single file. It is the strongest available evidence that the detector classifies by syntactic shape and never consults semantic (the §11.4.250 primitive named in BOB-19 BOB-216). REACHABILITY, STATED HONESTLY (§11.4.6): the script is invoked by NOT control-needle-proven (91 needle hits, 0 control) it is referenced only by its own its own docstring, and a tracker note; 2 across *.sh / *.yaml / *.py / Makefile or tools/. Its own README self-declares "not by the normal start/stop flow". Last full commit 2026-04-12. So this is NOT live automated path. It IS reachable by a hard update, which is exactly what the tool for. Severity is Critical on the capabilities combination, bounded by that reachability on an active exploitation path. ACCEPT plugin sources are pinned (commit SHA or hash) and verified before write; (2) an unverifiable source REFUSES and names wh

ATM ID	Type	Status	Severity	Description
				failed (§11.4.252) rather than proceeding to the syntax pass; (3) the compile() call is done in-source as a syntax check that is NOT a gate, so nobody reads it as one; (4) a failure serving a syntactically-valid hostile plugin by asserting it is REFUSED pre-fix-absent, pre-fix-present; (5) golden-FALSE proving a legitimate pinned update still succeeds (§11.4.201(1)). DISCOVERY CHANNEL (§11.4.201(1)). found by the concealed-hits triage stream, establishing that the gate's four hits in the area were false positives. Not by the area QA regime – and the regime that WAS pointed reported the wrong three lines. BOB Queued major WHAT: tools/README.md states "the backup is restored" on valid failure. Conductor-verified: shutil.copy EXACTLY ONCE in tools/plugin_update_auto and copies FORWARD only – a reverse-direction restore has ZERO occurrences (grep control needle-proven seeing: needle 2 hits, needle control 0). The plugin write opens in mode which TRUNCATES IMMEDIATELY. USER-OBSERVED HARM (the reason this is not merely a defect): a failure part-way through the leaves a TRUNCATED, NON-IMPORTABLE plugin on disk. The operator is told the update failed reasonably concludes the previous file is because the README says it was restored not. The next ./install-plugin.sh copies corrupt file into config/qBittorrent/novengines/ and that search engine SILENTLY WORKING. The .bak needed to recover DOES disk; the tool never mentions it and never it. This is a §11.4 documentation-layer with a real downstream consequence: the asserts a safety property the code does not implement, and the operator's recovery is made on that false assertion. SECOND DOC DIVERGENCE: the README claims JSON to stdout; :274 writes it to a FILE (open(args.output, "w")). THIRD, SEPARATE DEFECT in the same file (recorded here not than as its own item because it shares the and the fix window): _extract_version at uses a BAREexcept:, so a Ctrl-C during the 14-second is SWALLOWED. That is a signal-handling not a fail-open – the gate flagged this for the wrong reason (it read the silent

ATM ID	Type	Status	Severity	Description
				return; the real issue is the bare except catching KeyboardInterrupt). ACCEPTANCE either the rollback is IMPLEMENTED (res the .bak on failure) or the README claim DELETED – the doc and the code must agree (§11.4.6); if implemented, write to a t and rename atomically rather than trunc place; (2) the stdout-vs-file claim cor (3) the bare except narrowed so Keyboar propagates; (4) a RED that fails the wr way and asserts the previous plugin is (post-fix) / truncated (pre-fix). REACH same as the sibling item – hand-run only any automated path, last functional com 2026-04-12. Severity Major on the harm s bounded by that reachability. DISCOVERY (§11.4.238): found by the concealed-hit stream. Not by the automated QA regime. BOB-219 Bug Queued major WHAT, c verified: docs/guides/tracker-credential TRACKED. Its §11.4.65-mandated export to guides/tracker-credentials.html and .pd EXIST ON DISK, are NOT tracked, and ARE matched by the .gitignore *credentials* at :31. The .md is rescued by an explic allowlist entry at :38; nobody added en the twins. WHY IT IS A LIVE VIOLATION A HYPOTHETICAL: §11.4.65 requires every in Markdown document to carry synchronized .html/.pdf siblings, and § requires every §11.4.65-scope doc to be from the README. Two artifacts that exi but can never be committed are, from any clone, ABSENT – so every clone of this has a tracker-credentials guide with no while the authoring host looks complete divergence is invisible on the machine notice it. WHY NOBODY SAW IT: this is a §11.4.201(6) FALSE-NUL of the BOB-212 status never listed the twins, so no ga author had a signal. The blind instrumen clean tree return the identical quiet z ANOTHER INSTANCE OF THE SAME MECHANISM, here rather than separately because it fix: docs/qa/BOB-124/evidence/loginctl_user_state.txt is swallowed by at .gitignore:~55 and is therefore uncor §11.4.83 QA evidence. Its SIBLINGS IN TH DIRECTORY – user1000_grepped.log, user_scope_events_head.log,

ATM ID	Type	Status	Severity	Description
				user_service_lifecycle.log – ARE tracked only by the robust glob negation !docs/*.log. That one file is lost purely because is .txt rather than .log. The pattern in robust glob negations hold; per-file and extension rescues leak. ACCEPTANCE: (1) twins become trackable and are committed alongside their .md; (2) the BOB-124 .txt evidence likewise; (3) whichever BOB-212 direction is chosen, it MUST cover these that closes the future-swallow while leaving these three artifacts permanently uncommitted has addressed the mechanism and not the (4) a check that a tracked .md in §11.4 has COMMITTABLE twins, so this class can silently. DISCOVERY CHANNEL (§11.4.238) by the BOB-212 blast-radius sweep – and its SECOND pass. The first pass filtered the source-extension set that omitted .pdf, this finding entirely; the agent re-ran the extension filter over all 420 non-artifacts and recorded the blind spot rather than the first number. Worth keeping: an external allowlist is itself a false-null generator is the same shape as the defect being investigated. BOB-220 Bug Queue WHAT: scripts/ownership_repair.sh:891 chmod 755 intending to strip setuid/setgid Traced live: the chmod RUNS and SUCCEEDS mode stays 2755. Root cause measured – (with a 3-DIGIT symbolic-equivalent octal PRESERVES the setgid bit on DIRECTORIES 4-digit form (00755) or an explicit g-s it. The comment at :868-884 describes a that does not occur for directories. E benign today – the surviving setgid bit itself harmful, and no defect is known from it. This is filed as a §11.4.6 accepted defect: an in-source comment asserting the code does not perform. That matters the next reader will trust it, and because future security-relevant strip written the same pattern would silently fail the way. RELATION TO BOB-207: the same strength measured that after repair a new file in gid 1000 with THE SETGID BIT STILL SET facts compound. If BOB-207 is resolved by narrowing the repair (the recommended direction) the setgid survival becomes moot for that but the misleading comment remains. ACCEPTANCE:

ATM ID	Type	Status	Severity	Description
				(1) either the strip is made real (00755) or the comment is corrected to state that directories retain setgid – code and comments agree; (2) if made real, a RED asserting 2755 -> 0755 on a directory, since the code form silently no-ops; (3) golden-FALSE p directory that SHOULD keep its mode is not gratuitously changed. DISCOVERY CHANNEL (\$11.4.238): found by the BOB-207 stream tracing an unrelated behaviour. Not by automated QA regime. BOB-221 Bug critical WHAT: scripts/pre_build_verification.sh invariant 30 UNIT-TESTS-EXECUTED) enumerates suites in FILESYSTEM GLOB (:1196) and calls fail(non-zero exit. It therefore RUNS untracked suites, and it has NO concept of a test SUPPOSED to fail. MEASURED: tests/pre_build_verification.sh exits correctly, because it is a RED test for an unfixed defect. Invariant 30 counts a gate failure. The predicted T042 verdict is and this is one of its three blocking cases. THE STRUCTURAL PROBLEM: \$11.4.115 and \$11.4.120 REQUIRE a RED authored FIRST and OBSERVED before the fix exists. \$11.4.135 requires to persist as the permanent regression (the discipline mandates that failing tests in the tree between authoring and fixing the blocking gate treats their existence as a defect. Following the constitution correct makes the gate refuse the commit. That is \$11.4.120 wrong-seam problem: the gate asserts "no suite fails" when the invariant it asserts is "no suite fails UNEXPECTEDLY" SURFACED NOW: this session authored FOUR across parallel streams (BOB-204, BOB-207, BOB-212) – the first time the code was applied at this volume. Previously it flipped GREEN within the same round, so the window never spanned a gate run. The defect is not new; the exposure is. THE FORBIDDEN RESPONSES (\$11.4.120): do NOT delete the code to make the gate green; do NOT weaken invariants to ignore failures; do NOT mark the RED without a tracked reason. Each converts a signal into silence. FIX DIRECTION – the \$11.4.248's quarantine mechanism, which the constitution already specifies and this has not wired: a RED declares its expectation

ATM ID	Type	Status	Severity	Description
				failing status and its tracked item (a marker, a naming convention, or a manifest invariant 30 reads that declaration, and declared-RED failure is reported as EXPIRED a fail) while an UNDECLARED failure still Crucially the declaration must EXPIRE on tracked – §11.4.248 pairs quarantine with stabilisation deadline precisely so "expired fail" cannot become permanent cover. A tracked item closes must flip GREEN or the gate FAIL on the stale declaration. ACCEPTANCE declared RED does not block; (2) an UNDECLARED failing suite still blocks (the §11.4.248 guard – a fix that ignores all failures strictly worse than the defect); (3) a declared RED whose tracked item is CLOSED blocks declarations cannot rot; (4) a paired §11.4.248 mutation removing the declaration-check gate accept an undeclared failure -> gate DISCOVERY CHANNEL (§11.4.238): found by readiness preflight, before the endgame than during it. Not by the automated QA the regime IS the thing that would have === CORRECTED 2026-08-26 – MY FIX DIRECT THIS ITEM WAS WRONG, AND THE BLOCKER IS (§11.4.6) === CORRECTION 1 – §11.4.248 THE MECHANISM. I wrote "this is §11.4.248 quarantine mechanism, which the constitution already specifies and this project has not wired." That is half right and the wrong matters. §11.4.248(A) QUARANTINE targets tests – its trigger is literally "two-consecutive-run-different-verdict OR red", and its remedy is to MOVE the suite tests/quarantine/ and run the blocking WITHOUT it "so green means green". §11.4.248 PROTECTED-SPEC is a tag plus a required gate on MODIFYING a regression test; it says a test may fail. A RED is DETERMINED MUST STILL BE RUN – §11.4.115(F) and §11.4.248 require the RED verdict to be PRODUCED as evidence. Excluding it destroys the very the discipline mandates. Merging the two also let a genuinely flaky suite hide behind a RED declaration and vice versa. What §11.4.248 legitimately supplies, and what should be INHERITED rather than re-invented (§11.4.248) the SHAPE: a by-name list + a tracked item deadline + a must-only-shrink ratchet. CORRECTION 2 – THIS IS A LANGUAGE-PARITY

ATM ID	Type	Status	Severity	Description
				A DESIGN VACUUM. Conductor-verified: the ALREADY runs this mechanism on the PYTHON pytest.mark.xfail(strict=True) is used deliberately for OPEN defects at tests/test_scaling_envelope.py:907 (BOB-167, c in tests/scaling/README.md:64) and tests/test_plugin_parsers_stress_chaos.py:90 - own comments carry the ratchet disciplin verbatim ("it stays visible as xfailed : report", "then remove this xfail"). So "expected-failure, strict so an unexpected fails" is ALREADY accepted policy in one language. The BASH side has no equivalent is the real gap. CORRECTION 3 – BOB-222 SUFFICIENT TO UNBLOCK T042. A full repl invariant 30 measured RAN=38 FAILED=4 SKIPPED=2: rc=124 300s test_compute_badges_carrier_match.sh < not a RED. Blocks independently. Filed separately. rc=1 3s test_ownership_gid_agreement.sh < BOB-207's RED (a SECOND in-glob RED; the assumed one) rc=1 1s test_bob205_danger_roots_scope.sh < BOB-205's RED rc=127 9s test_check_cm_lan_routes_authenticated. CONTAMINATED: a sibling stream was writ lan_route_auth_analyzer.py during and a run (§11.4.119 – the surveying stream d that resource and correctly declined to adjudicate). rc=127 is the §11.4.1 scrip internal FAIL-bluff signature, not a pr verdict either way. Returned to its own stream. ALSO: BOB-204's and BOB-212's R tests/security/test_gitignore_swallow_i which is OUTSIDE invariant 30's glob and by NOTHING (BOB-222) – they do not block and widening the glob would immediately another blocker. THE DESIGN, RECOMMEND place declaration + SSoT expiry + strict semantics. THREE independent facts must before a failure is excused – (1) the s listed in scripts/lib/expected_red.sh, a PRODUCING streams do not own; (2) the s itself carries# EXPECTED-RED: with id; (3) <ID> is OPEN in docs/workable_i FAIL-CLOSED on unreadable store or unk (§11.4.252). Plus STRICT-XFAIL PARITY: a suite that PASSES blocks, which mechan forces the ratchet to shrink in the same

ATM ID	Type	Status	Severity	Description
				as the fix. EXIT-CODE CONVENTION REJECT MEASURED EVIDENCE – and I had flagged it as promising. The non-{0,1} exit space is CLAIMED IN THIS REPO FOR THE OPPOSITE MEANS test_gitignore_swallow_is_loud.sh uses "INSTRUMENT BROKEN or SECRET LEAK – version void", and test_bob205_danger_roots_scope exit 3 = ABORT (instrument blind). Both chosen precisely so a blind harness can read as a verdict. Overloading either for "expected red" would make a genuinely BLIND INSTRUMENT INDISTINGUISHABLE FROM A DECISION – the gate would swallow exactly the false class those codes exist to make loud. If fails acceptance (4) (an integer carries id) and (3) (nothing to rot-check), and the declaration inside the PRODUCER, code producer!=gate (§11.4.240/§11.4.249). NO BOUNDARY ON THE DESIGN (§11.4.240): it is separation by LOCATION and MULTI-PLACE A not by true CAPABILITY, which §11.4.240 There is no PR/CODEOWNERS seam here to capability – CLAUDE.md Hard Stop #1 remove CI/PR gates, so the CODEOWNERS half of §11.4.248(B) is STRUCTURALLY UNENFORCEABLE this project. What the design buys is the silencing a failure requires a coherent place story visible in a diff, instead of comment line. THE RED: tests/pre_build, test_bob221_expected_red_declaration.sh extracts invariant 30's loop and its block predicate VERBATIM FROM THE LIVE GATE BY MARKER (never line number) and RUNS then a hermetic scratch PROJECT_ROOT – so the under test is the gate's own text, not a paraphrase (§11.4.226 anti-echo). Measurement of 5 properties unmet, exit 1. P3 is as the blocking REASON, not merely on "it is today everything blocks, so a bare did-check would pass FOR THE WRONG REASON and passing if the anti-rot half were never Polarity flip proven with the BYTE-IDENT file against a sandbox carrying the patch 0, all five properties met. Four paired mutations each kill exactly ONE property one, no cross-talk. THE PATCH: 72 lines + one new file scripts/lib/expected_red apply -checkclean, NOT APPLIED. Operating the landing commit must not miss: the test test_bob205_danger_roots_scope.sh and

ATM ID	Type	Status	Severity	Description
BOB-222	Bug	Queued	major	test_ownership_gid_agreement.sh, but NE carries an# EXPECTED-RED:` marker t (verified 0 in both) — without those two additions the gate blocks them with"dec the file carries no matching marker", w fail-closed design working as intended, SEQUENCING RECOMMENDATION: (i) bounded variant of (i) — land the mecha declaring exactly BOB-205, BOB-207 and item's own suite, add the two missing m triage the rc=124 hang as its own item, the rc=127 to its owner, THEN run T04 HONEST COST, STATED NOT HIDDEN. modifies the blocking gate BEFORE tha ever run clean, so the mechanism's first exercise IS the T042 run. The circularit unavoidable and IS this item (§11.4.120 whose precondition is produced by the gates): a clean T042 run is impossible w RED exists, so "validate the gate before it" cannot be satisfied. Risk reduced as possible without running the gate (prov applicable patch, proven polarity flip, fo mutations, P2 undeclared-failures-still-b asserted and mutation-proven) but NOT eliminated. Against (ii) fix-the-four-defe all four are Queued and genuinely defer BOB-212's fix direction is an explicitly u §11.4.66 OPERATOR decision whose ow deliberately written fix-direction-agnost not to prejudge it — choosing (ii) means that decision on the operator's behalf, p implementations and four reviews, and leaves the hang and the rc=127 blockin RECURSION NOTE: this item's own RE glob and failing, so it is itself a 5th bloc the mechanism lands — at which point i already-present marker and table row c The mechanism is its own first custome WHAT: scripts/pre_build_verification.sh enumerates bash suites with a glob cov EXACTLY three directories: "\$ {PROJECT_ROOT}"/tests/unit/test_*.sh {PROJECT_ROOT}"/tests/pre_build/test {PROJECT_ROOT}"/tests/hooks/test_*.sh security/ is NOT among them. Conducto verbatim. So tests/security/ test_gitignore_swallow_is_loud.sh — a F authored this session with a golden-FAL proving real secrets stay ignored — is e

ATM ID	Type	Status	Severity	Description
				by NOTHING. It is a guard that guards and its silence is indistinguishable from THIS IS THE THIRD OCCURRENCE OF CLASS. The driver's OWN comment at : records the history: the same defect class "existed for tests/pre_build/test_*.sh" and fixed by adding that directory to the glob. It recurred one directory over (tests/hooks) the same way. Now tests/security. Each new glob entry; none addressed why a new directory is invisible by default. §11.4.2 APPLIES DIRECTLY: three symptoms, one primitive. The primitive is a hand-maintained enumeration that must be edited in lockstep with the tree, whose failure mode is SILENT. It has the identical shape as BOB-205's DANGER and BOB-212's .gitignore allowlist — the separate hand-maintained lists in this repository were three measured to have silently missed something. Adding tests/security to the list would be the fourth instance of layer N. THE GATE ALREADY HAS THE RIGHT at :1220: it fails when the glob matches NOTHING ("the glob is blind"). That guard catches a TOTALLY blind glob but not a PARTIALLY blind one — the more common, more dangerous case, because a partially blind glob still reports a healthy count. FIX D (§11.4.251 role-as-data-pack): derive the list from the tree — every tests/**/test_*.sh is a DECLARED §11.4.224(E) exclusion feature with justification per entry. Then a new test cannot be invisible, and a deliberate exclusion is visible and reasoned. If a hand list is kept, omission-guard is the same computation; the derivation must be built either way. ACCEPTANCE: (1) tests/security suites (2) a NEWLY CREATED tests//test_x.sh is set up with no hand edit — that is the invariant that stops the recurrence, and without it this is the fourth patch; (3) a RED creating such a directory and asserting it runs; (4) the PARTIALLY blind-glob guard is extended to catch PARTIAL blindness, not only total. DISCOVERY C (§11.4.238): found by the T042 readiness test before preflight. Not by the automated QA regression, notably not by the two previous fixes of this class, neither of which asked why it happened. WHAT, both conductor-verified with conformance needles: CM-SCRIPT-DOCS-SYNC occurred
BOB-223	Bug	Queued	major	

ATM ID	Type	Status	Severity	Description
				scripts/pre_build_verification.sh = 0 (control needle CM-MARKDOWN-EXPORT-SYNC the instrument sees). §11.4.44 revision-enforcement likewise 0 hits (control needle Neither §11.4.18’s companion-doc mandate §11.4.44’s revision header is enforced by invariant. THE PERVERSE CONSEQUENCE MEASURED: a new script with NO companion doc passes the gate. Writing the companion that §11.4.18 MANDATES creates docs/scripts/.md, which invariant 16 (CM-MARKDOWN-EXPORT-SYNC) then requires have .html and .pdf twins — and their absence a BLOCKING failure. This session hit it docs/scripts/test_gitignore_swallow_is_1 {html,pdf} are missing and are two of invariant 16’s six violations. So the gate’s incentive gradient points AWAY from the constitution complying with §11.4.18 is punished, if it is free. That is worse than an ungated rule a rule the machinery actively discourages §11.4.227 IS THE GOVERNING ANCHOR named gate that exists only in prose is closed and the ledger of unimplemented CM-* must be monotone-decreasing. CM-SCRIPT-DOCS-SYNC is named in §11.4.18’s own implemented nowhere — one concrete rule exactly the 58%-unimplemented population §11.4.227 was minted to shrink. ACCEPT (1) either CM-SCRIPT-DOCS-SYNC is implemented, or it is registered as a dependency pointing at a tracked §11.4.197 item — absence is what §11.4.227 forbids; (2) since §11.4.44’s header check; (3) whichever the incentive inversion is closed: it must be cheaper to skip a mandated doc than to create — if invariant 16 will demand twins, the creation path must produce them, or invariant must scope out docs/scripts until it can, paired §1.1 mutation per gate implemented HONEST NOTE ON SCOPE: this item demands argue §11.4.18 should be enforced immediately that is an operator call about gate debt (§11.4.66). It argues the CURRENT state incoherent: an unenforced mandate whose observance triggers a different gate’s failure Either enforce both ends or neither. DISCHANNEL (§11.4.238): found by the TO readiness preflight while explaining why

ATM ID	Type	Status	Severity	Description
				file broke invariant 16. Not by the automaton regime. WHAT: a replication of invariant 30 (same skip list, same BOBA_PREBUILD_NESTED=1, same timeout(300) measured RAN=38 FAILED=4 SKIPPED=1. One of the four failures is tests/unit/test_compute_badges_carrier_match.sh. rc=124 after the FULL 300 seconds not fail, it HANGS. WHY IT IS FILED SEPARATELY AND URGENTLY: it blocks invariant 30, and therefore T042, INDEPENDENT OF BOB-221. The assumption in BOB-221 that landing an expected-RED mechanism under T042 is FALSE as stated — two of the four failures are REDs, one is this hang, one is contaminated. Landing the mechanism leaves T042 blocked by this suite. IT MUST BE SILENCED BY A DECLARATION. A non-§11.4.232(C) liveness failure, not a verdict wedged up and a progressing op both labeled “not finished yet”, and marking it expected would convert a §11.4.201(6) false-null to permanent cover. That is exactly the abiding expected-RED design property (2) exists to prevent, so it must be triaged as its own INVESTIGATION DIRECTION (§11.4.100 guessing): rc=124 is the timeout(1) signature. Determine WHERE it wedges — a consumer blocked on an unclosed producer write- documented shape here (§11.4.201(12)) that a background watchdog spawned in (...) command-substitution inherits the process end, and an early disarm orphans its sleeping grandchild, so the substitution stalls for budget while every verdict and exit code is CORRECT). That signature — full budget verdicts — matches rc=124 exactly and is the FIRST hypothesis tested, not the last. countermeasure is documented: redirect watchdog subshell fds away from the consumer pipe, or have the probe write to a file. Do not assume that is the cause; it is the highest hypothesis given the recorded precedent. ACCEPTANCE: (1) the wedge point is identified with captured evidence, not inferred; (2) completes deterministically well inside budget; (3) a RED reproducing the hang regression cannot silently re-wedge (a test-based assertion, since the failure IS the
BOB-224	Bug	Queued	critical	

ATM ID	Type	Status	Severity	Description
BOB-225	Bug	Queued	major	(4) NOT closed by a declaration or by raising a timeout — raising the budget hides it. FURTHER DATE: the suite is dated 2026-08-21, so it predates this session. DISCOVERY CHALLENGE (§11.4.238): found by the BOB-221 designer while surveying invariant 30 more widely than the brief required — the T042 preflight had only 3 of 38 suites and stated that bounds were honest, which is what prompted the wide survey. WHAT, conductor-verified: .gitignore:26*.docx globally. The §11.4.65 export pipeline GENERATES .docx twins — the workbook export produces Issues.docx / Fixed.docx / Issues_Summary.docx / Fixed_Summary.docx; the doc exporter produced docs/scripts/check_cm_lan_routes_authenticated.docx around 9. Every one of them is untrackable in construction: they exist on disk, git will not track them, and no gate can notice because the absence is silent. WHY THIS IS THE BOUNDARY CLASS, NOT A DUPLICATE OF IT: BOB-225 deny-all glob plus a hand-maintained per-project ALLOWLIST, where new files leak through gaps in the list. This is a deny-all glob without an allowlist at all for a file type the project MANDATES producing. The mechanism for the false-null is identical — git status stays so the exporter appears to succeed and the artifact appears to exist. It is filed separately §11.4.214 (distinct-but-similar), with BOB-224 and BOB-219 as siblings. THE TENSION IS TO RESOLVE HONESTLY: §11.4.153 mandates a FOUR-format export (HTML + PDF + DERIVATIVE) its document class, and §11.4.65 governs the twins generally. So the constitution requires producing an artifact the repository is committed to refuse. One of the two is wrong and the resolution is an operator decision (§11.4.153) the .docx mandate applies here and the .docx carve out generated doc twins; (b) .docx is deliberately untracked as a heavy binary derivative regenerable per §11.4.77 from source in which case the EXPORTERS should stop producing it, or produce it into an explicitly untracked location, and the §11.4.153 formal requirement should be recorded as consciously not-adopted rather than silently unmet. WHAT IS NOT acceptable is the present state: generate and ignore it, and let both the mandate and

ATM ID	Type	Status	Severity	Description
				appear satisfied. MEASURED SCOPE (CORRECTED — my first write of this it 'tracked .docx files = 0', which is FALSE recorded here per §11.4.6 rather than s amended): 2 .docx files ARE tracked and exist repo-wide, so 1138 are untracked ignored. (A second correction, also recorded rather than amended: my first correction 344, which counted only the docs/ subtr numeric errors in a row on one item — pattern is that each was measured with narrower instrument than the claim it s which is the §11.4.201(7)(c) path-is-part instrument failure applied to my own re AND THE TWO SURVIVORS ARE THE INTERESTING PART: they are docs/feat Status.docx and docs/features/ Status_Summary.docx — precisely the p §11.4.153 explicitly mandates as a FOU export. So the only two DOCX artifacts see are the two a specific anchor named survive not by rule but because they are in the index. That makes this a PARTIAL condition, not a total one, and the two s are the interesting part — they are in the position as frontend/e2e/credentials.spe BOB-212: alive only because they are al the index, since git honours the index over .gitignore for tracked paths. One d re-add, one file move, and they vanish s any other. So the state is worse than a c never track docx': it is an inconsistent c two artifacts appear to prove the forma tracked while 342 prove it is not. ACCE (1) the operator decision above is taken recorded; (2) whichever way, the export ignore rule AGREE — if .docx is not trac nothing should silently generate one int tracked doc directory; (3) if carved out, that a generated twin is actually tracka cannot recur silently; (4) §11.4.153 com either met or recorded as an honest gap left implicitly failing. DISCOVERY CHAL (§11.4.238): found by the BOB-102 roun remediation stream when it regenerated guide twins and noticed the .docx could added. Not by the automated QA regime the regime cannot see it, which is the p WHAT: ownership_repair walks a declar and repairs items whose uid is not the c
BOB-226	Task	Queued	major	

ATM ID	Type	Status	Severity	Description
BOB-227	Bug	Queued	critical	The unit suite seeds a foreign uid only c and SYMLINKS; interior DIRECTORIES operator-owned (case 22 seeds only a fo declared ROOT, on the failure path). Pro first-start repairs exactly the untested s MANIFEST: tests/unit/test_ownership_r seed_tree/seed_wrong; scripts/ ownership_repair.sh walk at :994. REPF tree whose interior directories carry uid via podman unshare, run the repair, obs automated assertion covers the outcom UNTESTED: the unprivileged harness c create symlinks inside a directory it no owns, which cases 8/9/18 require. The DECLARED GAPS note cross-references ownership/test_container_writes_owned but that covers the CREATION side (FR the repair-side walk. ACCEPTANCE: an integration-layer test (where the unpriv harness constraint does not bind) that s foreign-owned interior directories, runs repair, and asserts post-state ownership mode preservation. Surfaced by the BO independent review 2026-08-27. WHAT: three of the four artifacts of the ROUTES-AUTHENTICATED pre-build g untracked in git. MEASURED 2026-08-2 ls-files -error-unmatch, control-needed known-tracked file: scripts/pre_build/ lan_route_auth_analyzer.py UNTRACKED pre_build/check_cm_lan_routes_authentic UNTRACKED, tests/pre_build/ test_check_cm_lan_routes_authenticat UNTRACKED; only docs/scripts/ check_cm_lan_routes_authenticated.md TRACKED. IMPACT: (1) losing this chec an entire security gate plus 197 assertio round-over-round diff claim across revie 8 through 14 was ever checkable, becau committed baseline exists - the same \$1 evidence-custody failure the BOB-195 c independently; (3) a fresh clone runs a p gate whose implementation is absent. ACCEPTANCE: all four artifacts tracked committed, and a gate asserting that ev executable a pre-build invariant invokes tracked. Surfaced by the BOB-102 roun remediation and independently verified 2026-08-27.

ATM ID	Type	Status	Severity	Description
BOB-228	Task	Queued	minor	WHAT: §11.4.212 makes the main README canonical entry point for ALL project documentation, with no §11.4.65-scope reachable by no link path. docs/scripts/check_cm_lan_routes_authenticated.md reachable from README.md. MEASURE 2026-08-27: grep -c for the guide name README.md returns 0, control-needed doc README does link (CONTINUATION 1), so the instrument is not blind. ACCESS README links the guide directly or transitively and the doc-link generator covers docs/ the next such guide cannot land orphan. Surfaced by the BOB-102 round-13 remediation and independently verified 2026-08-27.